

AI Software Supply-Chain Security and Vulnerability Detection: A Survey

Modern AI and software systems depend on long chains of source code, open-source packages, build tools, containers, datasets, models, and deployment services. These chains create attack surfaces in which vulnerable dependencies, malicious packages, compromised repositories, poisoned artifacts, and insecure generated code can propagate at scale. This survey synthesizes an arXiv-derived corpus of 300 papers collected during this run and organizes the literature around software supply-chain threats, dependency ecosystems, vulnerability detection, AI and LLM-based code security, malicious package detection, SBOM and provenance mechanisms, patching and repair, ML model supply-chain risks, and evaluation. The survey argues that AI software supply-chain security requires joint reasoning over code, dependencies, metadata, provenance, models, and operational context.

Keywords:

software supply-chain security; vulnerability detection; open-source dependencies; malicious packages; SBOM; provenance; LLM code security; vulnerability repair

1 Introduction

Software is assembled from source files, packages, transitive dependencies, build tools, containers, deployment scripts, datasets, and model artifacts. AI has intensified this dependence: developers use code models, organizations deploy ML components, and applications integrate large open-source stacks. The same connectivity that accelerates development also creates supply-chain risk. A vulnerable dependency, malicious package, compromised build step, poisoned dataset, or unsafe generated code can affect many downstream systems [28, 146, 150, 159, 234, 268, 283, 294].

Vulnerability detection and supply-chain security are therefore converging. Classical program analysis identifies code defects and security flaws. AI-based detectors learn patterns from vulnerable code, dependency metadata, package behavior, and exploit reports. Supply-chain mechanisms such as SBOMs, provenance, signing, and reproducible builds try to make software composition observable and auditable. These components must work together because neither code analysis nor metadata governance alone is sufficient [28, 59, 146, 150, 159, 234, 283, 294].

This survey reviews AI software supply-chain security and vulnerability detection as an end-to-end problem. We consider software packages, code, build artifacts, containers, ML models, datasets, and evaluation pipelines.

2 Background

2.1 Software Supply Chains

A software supply chain includes upstream source repositories, package managers, dependency graphs, build systems, continuous integration, release pipelines, container registries, and deployment environments. Supply-chain attacks exploit trust relationships across these components. Dependency confusion, typosquatting, package hijacking, maintainer account compromise, malicious updates, and build tampering are common patterns. Defensive systems need visibility into both code and metadata [28, 59, 146, 150, 159, 234, 283, 294].

2.2 Vulnerability Detection

Vulnerability detection uses static analysis, dynamic analysis, symbolic execution, taint analysis, fuzzing,

learned code representations, and LLM-based reasoning to find security flaws. Detection can operate at the level of functions, files, commits, packages, containers, or dependency graphs. The main difficulty is balancing recall and precision under changing code, noisy labels, incomplete vulnerability reports, and evolving exploit patterns [28, 59, 146, 150, 159, 248, 268, 294].

2.3 AI-Based Code Security

Deep learning and language models encode code syntax, data flow, control flow, comments, and vulnerability descriptions. They support classification, localization, patch suggestion, exploitability prediction, and security review. Graph neural networks can model program dependence graphs; transformers can model token sequences; LLMs can reason over natural language advisories and code. Yet AI detectors can overfit benchmarks, miss semantic constraints, and produce insecure patches [28, 59, 110, 146, 150, 159, 234, 283].

2.4 Supply-Chain Metadata and Provenance

SBOMs, provenance records, signatures, attestations, reproducible builds, and container scans provide evidence about what software contains and how it was built. Provenance does not automatically prove safety, but it makes risk analysis, incident response, dependency triage, and compliance more systematic. AI can help infer missing metadata, prioritize risks, and detect anomalous packages, but metadata quality remains a limiting factor [5, 40, 110, 139, 144, 155, 222, 225].

3 Methods

3.1 Search Protocol and Corpus Construction

The corpus for this survey was generated during this run from the arXiv structured API. Queries combined the task topic with software supply-chain security, open-source dependencies, vulnerable dependencies, package ecosystems, npm, PyPI, Maven, malicious packages, dependency confusion, typosquatting, software bills of materials, SBOM, provenance, reproducible builds, containers, vulnerability detection, software vulnerability, static and dynamic analysis, taint analysis, symbolic execution, deep learning, large language models, code language models, graph neural networks, AI-generated code se-

curity, automated program repair, vulnerability repair, CVE/CWE, Big-Vul, Devign, Juliet, SARD, ML model supply chains, model repositories, backdoors, and dataset provenance. Records were retained when title or abstract evidence connected them to software supply chains, dependency security, package abuse, vulnerability detection, code security, provenance, patching, or AI/ML artifact security. Duplicates were removed by arXiv identifier, and the final bibliography cites 300 unique scholarly preprints.

3.2 Taxonomy

We organize the literature along eight axes. The first is *asset*: source code, dependency, package, build artifact, container, dataset, model, or deployment configuration. The second is *threat*: vulnerability, malicious package, typosquatting, dependency confusion, build compromise, backdoor, poisoning, or insecure generated code. The third is *signal*: code tokens, abstract syntax trees, control/data flow, dependency graphs, metadata, provenance, advisories, execution traces, or natural language. The fourth is *analysis method*: static analysis, dynamic analysis, fuzzing, symbolic execution, graph learning, transformers, LLM reasoning, or anomaly detection. The fifth is *action*: detect, localize, explain, patch, prioritize, attest, quarantine, or monitor. The sixth is *scope*: project, package ecosystem, container registry, organization, or ML model repository. The seventh is *evaluation*: precision, recall, false positives, exploitability, patch correctness, timeliness, and deployment cost. The eighth is *governance*: disclosure, compliance, maintainership, signing, policy, and incident response.

3.3 Dependency and Package-Ecosystem Security

Dependency graphs determine how vulnerabilities and malicious updates propagate. Security tools must reason about transitive dependencies, version constraints, reachability, maintainers, package behavior, and ecosystem norms. AI can help classify risk, infer suspicious behavior, and prioritize dependency updates, but deployment requires integration with package managers and developer workflows [28, 59, 146, 150, 159, 234, 283, 294].

3.4 Static, Dynamic, and Learned Vulnerability Detection

Static analysis provides soundness-oriented reasoning but can generate many false positives. Dynamic

analysis and fuzzing observe executions but may miss paths. Learned detectors can capture patterns across large corpora but are sensitive to label noise and distribution shift. Hybrid systems combine program analysis features with neural models and security knowledge to improve localization and triage [28, 59, 146, 150, 159, 248, 268, 294].

3.5 LLMs for Code Security

LLMs can summarize vulnerability reports, inspect code, generate patches, and reason over dependency advisories. They also introduce risks: hallucinated explanations, insecure generated code, prompt injection in developer tools, and overconfident patch suggestions. Effective use requires guardrails, tests, static checks, provenance-aware retrieval, and human review [28, 59, 110, 146, 150, 159, 234, 283].

3.6 Malicious Packages and Ecosystem Abuse

Malicious packages often exploit naming confusion, dependency resolution, maintainer compromise, install scripts, or obfuscated payloads. Detection uses metadata anomalies, package behavior, code similarity, maintainer history, network activity, and ecosystem graphs. Attackers adapt quickly, so detectors must be updated continuously and evaluated on recent package snapshots [134, 136, 159, 225, 234, 248, 276, 294].

3.7 SBOM, Provenance, and Build Integrity

SBOM and provenance systems expose software composition and build history. They support vulnerability matching, compliance, and incident response, but they face challenges in completeness, standardization, transitive dependency resolution, and trust. Build integrity depends on signed artifacts, reproducibility, isolation, and policy enforcement across CI/CD systems [5, 40, 110, 139, 144, 155, 222, 225].

3.8 Patching and Vulnerability Management

Detection is useful only if it leads to action. Vulnerability management includes exploitability assessment, dependency upgrade planning, patch generation, regression testing, and disclosure coordination. Automated repair and LLM-generated patches can accelerate remediation, but patch correctness and security regression remain hard to guarantee [29, 54, 59, 107, 169, 216, 218, 258].

3.9 AI and ML Artifact Supply Chains

AI systems add datasets, feature pipelines, embeddings, model weights, prompts, adapters, and model repositories to the supply chain. Model artifacts can contain backdoors, poisoned behavior, hidden licensing constraints, or undocumented training data. Model provenance and dataset lineage are therefore becoming part of software supply-chain security [21, 67, 81, 143, 211, 213, 241, 263].

3.10 Evaluation Methodology

Evaluation should report the asset type, threat model, dataset age, label source, train-test split, false-positive cost, patch validation method, ecosystem coverage, and deployment latency. Vulnerability detection benchmarks can overestimate performance when duplicates, temporal leakage, or project-level overlap are not controlled. Supply-chain evaluations should include time-to-detection, update freshness, package reachability, and developer workload [28, 110, 146, 150, 159, 234, 283, 294].

3.11 Representative Literature Map

The following map cites the retained corpus by theme, making the coverage explicit across supply-chain threats, vulnerability detection, AI code security, malicious packages, provenance, patching, ML artifact security, and evaluation.

Software supply-chain threats and dependency ecosystems The software supply-chain threats and dependency ecosystems cluster contains work that develops methods, systems, datasets, or analyses central to this survey [56, 110, 146, 150, 159, 234, 248, 283, 294]. A second strand in this cluster studies design trade-offs, evaluation protocols, failure modes, and domain-specific variants [5, 40, 135, 136, 155, 185, 225, 276, 290]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [11, 81, 94, 121, 139, 141, 169, 193, 267]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [21, 46, 64, 67, 143, 201, 211, 263, 295]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [3, 10, 37, 72, 88, 92, 103, 158, 241]. Additional retained studies broaden the cluster with alternative architectures, training signals,

data sources, and deployment assumptions [1, 6, 39, 42, 130, 167, 172, 199, 246]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [57, 69, 82, 86, 111, 148, 215, 253, 289]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [101, 104, 105, 123, 168, 182, 214, 224, 286]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [13, 66, 96, 147, 176, 208, 237, 291, 298]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [12, 153, 157, 162, 163, 195, 227, 273, 296]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [23, 25, 127, 131, 161, 183, 187, 189, 196]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [36, 80, 102, 114, 116, 179, 181, 221, 285]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [14, 26, 35, 74, 91, 133, 156, 198, 229]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [17, 60, 63, 70, 115, 120, 142, 191, 262]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [18, 55, 73, 166, 174, 175, 226, 230, 247]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [41, 75, 128, 154, 223, 232, 233, 272, 279]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [93, 124, 125, 138, 177, 190, 192, 261, 297]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [32, 43, 50, 68, 76, 89, 194, 238, 281]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [38, 47, 87, 109, 140, 160, 170, 173, 242].

Vulnerability detection and program analysis The vulnerability detection and program analysis cluster contains work that develops methods, systems, datasets, or analyses central to this survey [28, 54, 59, 188, 203, 216, 218, 266, 270]. A second strand in this cluster studies design trade-offs, evaluation protocols, failure modes, and domain-specific variants [19, 90, 129, 132, 151, 171, 207, 271, 277]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [27, 83, 98, 118, 145, 164, 249, 260, 269]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [112, 113, 126, 186, 209, 251, 274, 275, 299]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [16, 24, 58, 61, 62, 149, 236, 239, 259]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [8, 20, 33, 180, 202, 206, 256, 265, 288]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [9, 100, 178, 184, 197, 204, 257, 280, 284]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [4, 31, 119, 217, 292].

Deep learning and llm-based code security The deep learning and LLM-based code security cluster contains work that develops methods, systems, datasets, or analyses central to this survey [29, 52, 53, 77, 205, 255, 268, 278, 287]. A second strand in this cluster studies design trade-offs, evaluation protocols, failure modes, and domain-specific variants [45, 137, 165, 252, 254].

Malicious packages and ecosystem abuse The malicious packages and ecosystem abuse cluster contains work that develops methods, systems, datasets, or analyses central to this survey [134, 231, 243, 282].

Sbom, provenance, and build integrity The SBOM, provenance, and build integrity cluster contains work that develops methods, systems, datasets, or analyses central to this survey [34, 48, 49, 97, 144, 200, 210, 222, 245]. A second strand in this cluster studies design trade-offs, evaluation protocols, failure modes, and domain-specific variants [7, 99, 212, 235].

Patching, repair, and vulnerability management The patching, repair, and vulnerability management

cluster contains work that develops methods, systems, datasets, or analyses central to this survey [220].

Ai and ml model supply-chain security The AI and ML model supply-chain security cluster contains work that develops methods, systems, datasets, or analyses central to this survey [213].

Benchmarks, datasets, and evaluation The benchmarks, datasets, and evaluation cluster contains work that develops methods, systems, datasets, or analyses central to this survey [15, 65, 84, 107, 152, 219, 240, 244, 258]. A second strand in this cluster studies design trade-offs, evaluation protocols, failure modes, and domain-specific variants [2, 51, 78, 85, 117, 122, 228, 264, 300]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [22, 30, 44, 71, 95, 106, 108, 250, 293]. Additional retained studies broaden the cluster with alternative architectures, training signals, data sources, and deployment assumptions [79].

4 Challenges and Prospects

4.1 From Point Detectors to Supply-Chain Reasoning

Many tools classify a function, package, or advisory in isolation. Future systems need graph-level reasoning over dependencies, provenance, execution reachability, build steps, maintainers, and deployment context.

4.2 Data Quality and Temporal Evaluation

Vulnerability labels are incomplete and delayed. Benchmarks should control temporal leakage, duplicate code, project overlap, and post-disclosure artifacts. Evaluation should mirror deployment, where new vulnerabilities and packages arrive continuously.

4.3 Trustworthy LLM-Assisted Security

LLMs can help security teams, but their outputs must be checked. Future tools should combine LLM reasoning with retrieval, static analysis, tests, provenance, and patch validation rather than treating generated explanations or fixes as authoritative.

4.4 Securing AI Artifacts

Models, datasets, and adapters are now supply-chain artifacts. Provenance, signing, scanning, backdoor detection, dataset lineage, and policy enforcement will need to extend from code packages to ML repositories and deployment pipelines.

4.5 Operational Integration

Supply-chain security succeeds only when it fits developer workflows. Practical systems must prioritize risk, explain findings, automate safe updates, reduce false positives, and support incident response without overwhelming maintainers.

5 Conclusion

AI software supply-chain security and vulnerability detection require a unified view of code, dependencies, packages, builds, containers, datasets, models, and operations. This survey reviewed the literature across supply-chain threats, program analysis, AI-based code security, malicious package detection, provenance, patching, ML artifact risks, and evaluation. The central lesson is that security depends on connecting signals across the whole chain and validating AI assistance with rigorous analysis, provenance, and deployment-aware benchmarks.

References

- [1] Seyed Ali Akhavani, Behzad Ousat, and Amin Kharraz. Open Source, Open Threats? Investigating Security Challenges in Open-Source Software. *arXiv preprint arXiv:2506.12995*, 2025. URL <https://arxiv.org/abs/2506.12995>.
- [2] Mst Shapna Akter, Md Jobair Hossain Faruk, Nafisa Anjum, Mohammad Masum, Hossain Shahriar, Akond Rahman, Fan Wu, and Alfredo Cuzzocrea. Software Supply Chain Vulnerabilities Detection in Source Code: Performance Comparison between Traditional and Quantum Machine Learning Algorithms. *arXiv preprint arXiv:2306.08060*, 2023. URL <https://arxiv.org/abs/2306.08060>.
- [3] Vasileios Alevizos, George A Papakostas, Akebu Simasiku, Dimitra Malliarou, Antonis Messinis, Sabrina Edralin, Clark Xu, and Zongliang Yue. Integrating Artificial Open Generative Artificial Intelligence into Software Supply Chain Security. *arXiv preprint arXiv:2412.19088*, 2024. URL <https://arxiv.org/abs/2412.19088>.

- [4] Mohamed Mjd Alhafi, Mohammad Hammad, and Khlood Al Jallad. Vulnerability Detection Using Two-Stage Deep Learning Models. *arXiv preprint arXiv:2305.09673*, 2023. URL <https://arxiv.org/abs/2305.09673>.
- [5] Hala Ali, Andrew Case, and Irfan Ahmed. What You See Is Not What You Execute: Memory-Based Runtime SBOM Generation for Supply Chain Security. *arXiv preprint arXiv:2606.22827*, 2026. URL <https://arxiv.org/abs/2606.22827>.
- [6] Jahidul Arafat. How Deep Does Your Dependency Tree Go? An Empirical Study of Dependency Amplification Across 10 Package Ecosystems. *arXiv preprint arXiv:2512.14739*, 2025. URL <https://arxiv.org/abs/2512.14739>.
- [7] Ameen Asad and Andre Arko. Kettle: Attested builds for verifiable software provenance. *arXiv preprint arXiv:2605.08363*, 2026. URL <https://arxiv.org/abs/2605.08363>.
- [8] Syafiq Al Atiiq, Christian Gehrmann, and Kevin Dahlen. Vulnerability Detection in Popular Programming Languages with Language Models. *arXiv preprint arXiv:2412.15905*, 2024. URL <https://arxiv.org/abs/2412.15905>.
- [9] Jessy Ayala and Joshua Garcia. An Empirical Study on Workflows and Security Policies in Popular GitHub Repositories. *arXiv preprint arXiv:2305.16120*, 2023. URL <https://arxiv.org/abs/2305.16120>.
- [10] Laura Baird and Armin Moin. Cascaded Vulnerability Attacks in Software Supply Chains. *arXiv preprint arXiv:2601.20158*, 2026. URL <https://arxiv.org/abs/2601.20158>.
- [11] Laura Baird and Armin Moin. Towards Predicting Multi-Vulnerability Attack Chains in Software Supply Chains from Software Bill of Materials Graphs. *arXiv preprint arXiv:2604.04977*, 2026. URL <https://arxiv.org/abs/2604.04977>.
- [12] Giacomo Benedetti, Serena Cofano, Alessandro Brighente, and Mauro Conti. The Impact of SBOM Generators on Vulnerability Assessment in Python: A Comparison and a Novel Approach. *arXiv preprint arXiv:2409.06390*, 2024. URL <https://arxiv.org/abs/2409.06390>.
- [13] Varun Pratap Bhardwaj. Formal Analysis and Supply Chain Security for Agentic AI Skills. *arXiv preprint arXiv:2603.00195*, 2026. URL <https://arxiv.org/abs/2603.00195>.
- [14] Kawsar Ahmed Bhuiyan, Mohamed Bilel Besbes, Rachna Raj, Adam Al Assil, and Diego Elias Costa. Beyond Compliance: A Large Scale Study on the Completeness and Consistency of the GitHub SBOMs. *arXiv preprint arXiv:2607.04614*, 2026. URL <https://arxiv.org/abs/2607.04614>.
- [15] Yun Bian, Yi Chen, HaiQuan Wang, ShiHao Li, and Zhe Cui. Focus on What Matters: Fisher-Guided Adaptive Multimodal Fusion for Vulnerability Detection. *arXiv preprint arXiv:2601.02438*, 2026. URL <https://arxiv.org/abs/2601.02438>.
- [16] Dominik Blain. Broken Quantum: A Systematic Formal Verification Study of Security Vulnerabilities Across the Open-Source Quantum Computing Simulator Ecosystem. *arXiv preprint arXiv:2604.06712*, 2026. URL <https://arxiv.org/abs/2604.06712>.
- [17] Marcel Bohme, Eric Bodden, Tefvik Bultan, Cristian Cadar, Yang Liu, and Giuseppe Scan-niello. Software Security Analysis in 2030 and Beyond: A Research Roadmap. *arXiv preprint arXiv:2409.17844*, 2024. URL <https://arxiv.org/abs/2409.17844>.
- [18] Nicholas Boucher and Ross Anderson. Automatic Bill of Materials. *arXiv preprint arXiv:2310.09742*, 2023. URL <https://arxiv.org/abs/2310.09742>.
- [19] Tiago Brito, Mafalda Ferreira, Miguel Monteiro, Pedro Lopes, Miguel Barros, Jose Fragoso Santos, and Nuno Santos. Study of JavaScript Static Analysis Tools for Vulnerability Detection in Node.js Packages. *arXiv preprint arXiv:2301.05097*, 2023. URL <https://arxiv.org/abs/2301.05097>.
- [20] Jiuyang Bu, Wenkai Li, Zongwei Li, Zeng Zhang, and Xiaoqi Li. SmartBugBert: BERT-Enhanced Vulnerability Detection for Smart Contract Bytecode. *arXiv preprint arXiv:2504.05002*, 2025. URL <https://arxiv.org/abs/2504.05002>.
- [21] Jacopo Bufalino, Mario Di Francesco, Agathe Blaise, and Stefano Secci. SBOMproof: Beyond Alleged SBOM Compliance for Supply Chain Security of Container Images. *arXiv preprint arXiv:2510.05798*, 2025. URL <https://arxiv.org/abs/2510.05798>.
- [22] Steffen J. Camarato, Yahya Hmaiti, Mandana Ghadamian, and David Mohaisen. PromptAudit: Auditing Prompt Sensitivity in LLM-Based Vulnerability Detection. *arXiv preprint arXiv:2605.24171*, 2026. URL <https://arxiv.org/abs/2605.24171>.
- [23] Gianpietro Castiglione, Shahriar Ebrahimi, and Narges Khakpour. VeriSBOM: Secure and Verifiable SBOM Sharing Via Zero-Knowledge Proofs. *arXiv preprint arXiv:2602.13682*, 2026. URL <https://arxiv.org/abs/2602.13682>.
- [24] Ira Ceka, Feitong Qiao, Anik Dey, Aastha Valecha, Gail Kaiser, and Baishakhi Ray. Can LLM Prompting Serve as a Proxy for Static Analysis in Vulnerability Detection. *arXiv preprint arXiv:2412.12039*, 2024. URL <https://arxiv.org/abs/2412.12039>.
- [25] Carmine Cesarano, Vivi Andersson, Roberto Natella, and Martin Monperrus. GoSurf: Iden-

- tifying Software Supply Chain Attack Vectors in Go. *arXiv preprint arXiv:2407.04442*, 2024. URL <https://arxiv.org/abs/2407.04442>.
- [26] Carmine Cesarano, Martin Monperrus, and Roberto Natella. GoLeash: Mitigating Golang Software Supply Chain Attacks with Runtime Policy Enforcement. *arXiv preprint arXiv:2505.11016*, 2025. URL <https://arxiv.org/abs/2505.11016>.
- [27] Wachiraphan Charoenwet, Kla Tantithamthavorn, Patanamon Thongtanunam, Hong Yi Lin, Minwoo Jeong, and Ming Wu. AgenticSCR: An Autonomous Agentic Secure Code Review for Immature Vulnerabilities Detection. *arXiv preprint arXiv:2601.19138*, 2026. URL <https://arxiv.org/abs/2601.19138>.
- [28] Siyi Chen, Tianhan Luo, Shijian Wu, Xiangyu Liu, Yilin Zhou, Qi Li, and Wenyuan Xu. A Multi-Agent Framework for Automated Exploit Generation with Constraint-Guided Comprehension and Reflection. *arXiv preprint arXiv:2604.05130*, 2026. URL <https://arxiv.org/abs/2604.05130>.
- [29] Yizheng Chen, Zhoujie Ding, Lamya Alowain, Xinyun Chen, and David Wagner. DiverseVul: A New Vulnerable Source Code Dataset for Deep Learning Based Vulnerability Detection. *arXiv preprint arXiv:2304.00409*, 2023. URL <https://arxiv.org/abs/2304.00409>.
- [30] Zirui Chen, Qi Zhan, Jiayuan Zhou, Xing Hu, Xin Xia, and Xiaohu Yang. A Large-scale Empirical Study on the Generalizability of Disclosed Java Library Vulnerability Exploits. *arXiv preprint arXiv:2603.25997*, 2026. URL <https://arxiv.org/abs/2603.25997>.
- [31] Anton Cheshkov, Pavel Zadorozhny, and Rodion Levichev. Evaluation of ChatGPT Model for Vulnerability Detection. *arXiv preprint arXiv:2304.07232*, 2023. URL <https://arxiv.org/abs/2304.07232>.
- [32] Chun Yin Chiu. Towards a Zero-Trust Supply-Chain Assurance Rubric for ORAN RIC Applications. *arXiv preprint arXiv:2605.04249*, 2026. URL <https://arxiv.org/abs/2605.04249>.
- [33] Zhaoyang Chu, Yao Wan, Qian Li, Yang Wu, Hongyu Zhang, Yulei Sui, Guandong Xu, and Hai Jin. Graph Neural Networks for Vulnerability Detection: A Counterfactual Explanation. *arXiv preprint arXiv:2404.15687*, 2024. URL <https://arxiv.org/abs/2404.15687>.
- [34] Yekaterina Churakova, Mathias Ekstedt, and Larissa Schmid. Vexed by VEX tools: Consistency evaluation of container vulnerability scanners. *arXiv preprint arXiv:2503.14388*, 2025. URL <https://arxiv.org/abs/2503.14388>.
- [35] Aleksandr Churilov. The Range Shrinks, the Threat Remains: Re-evaluating LLM Package Hallucinations on the 2026 Frontier-Model Cohort. *arXiv preprint arXiv:2605.17062*, 2026. URL <https://arxiv.org/abs/2605.17062>.
- [36] Serena Cofano, Giacomo Benedetti, and Matteo Dell’Amico. SBOM Generation Tools in the Python Ecosystem: an In-Detail Analysis. *arXiv preprint arXiv:2409.01214*, 2024. URL <https://arxiv.org/abs/2409.01214>.
- [37] Avihay Cohen. JavaSith: A Client-Side Framework for Analyzing Potentially Malicious Extensions in Browsers, VS Code, and NPM Packages. *arXiv preprint arXiv:2505.21263*, 2025. URL <https://arxiv.org/abs/2505.21263>.
- [38] Josh Collyer, Tim Watson, and Iain Phillips. FASER: Binary Code Similarity Search through the use of Intermediate Representations. *arXiv preprint arXiv:2310.03605*, 2023. URL <https://arxiv.org/abs/2310.03605>.
- [39] Eric Cornelissen and Musard Balliu. NodeShield: Runtime Enforcement of Security-Enhanced SBOMs for Node.js. *arXiv preprint arXiv:2508.13750*, 2025. URL <https://arxiv.org/abs/2508.13750>.
- [40] Ludovic Courtes. Building a Secure Software Supply Chain with GNU Guix. *arXiv preprint arXiv:2206.14606*, 2022. URL <https://arxiv.org/abs/2206.14606>.
- [41] Sowmiya Dhandapani. Enhancing Software Supply Chain Security Through STRIDE-Based Threat Modelling of CI/CD Pipelines. *arXiv preprint arXiv:2506.06478*, 2025. URL <https://arxiv.org/abs/2506.06478>.
- [42] Maimouna Tamah Diao, Moustapha Awwalou Diouf, Iyiola Emmanuel Olatunji, Abdoul Kader Kabore, Gervais Mendy, Jacques Klein, and Tegawende F. Bissyande. Characterizing Build Compromises Through Vulnerability Disclosure Analysis. *arXiv preprint arXiv:2511.01395*, 2025. URL <https://arxiv.org/abs/2511.01395>.
- [43] Jens Dietrich and Behnaz Hassanshahi. On the Variability of Source Code in Maven Package Rebuilds. *arXiv preprint arXiv:2602.19383*, 2026. URL <https://arxiv.org/abs/2602.19383>.
- [44] Yangruibo Ding, Yanjun Fu, Omniyyah Ibrahim, Chawin Sitawarin, Xinyun Chen, Basel Alomair, David Wagner, Baishakhi Ray, and Yizheng Chen. Vulnerability Detection with Code Language Models: How Far Are We? *arXiv preprint arXiv:2403.18624*, 2024. URL <https://arxiv.org/abs/2403.18624>.
- [45] Tian Dong, Minhui Xue, Guoxing Chen, Rayne Holland, Yan Meng, Shaofeng Li, Zhen Liu, and Haojin Zhu. The Philosopher’s Stone: Trojaning

- Plugins of Large Language Models. *arXiv preprint arXiv:2312.00374*, 2023. URL <https://arxiv.org/abs/2312.00374>.
- [46] Ruian Duan, Omar Alrawi, Ranjita Pai Kasturi, Ryan Elder, Brendan Saltaformaggio, and Wenke Lee. Towards Measuring Supply Chain Attacks on Package Managers for Interpreted Languages. *arXiv preprint arXiv:2002.01139*, 2020. URL <https://arxiv.org/abs/2002.01139>.
- [47] Trevor Dunlap, Yasemin Acar, Michel Cucker, William Enck, Alexandros Kapravelos, Christian Kastner, and Laurie Williams. S3C2 Summit 2023-02: Industry Secure Supply Chain Summit. *arXiv preprint arXiv:2307.16557*, 2023. URL <https://arxiv.org/abs/2307.16557>.
- [48] Srimonti Dutta and Akshata Kishore Moharir. AgentRiskBOM: A Risk-Scoping Security Bill of Materials for Agentic AI Systems. *arXiv preprint arXiv:2606.21877*, 2026. URL <https://arxiv.org/abs/2606.21877>.
- [49] William Enck, Yasemin Acar, Michel Cukier, Alexandros Kapravelos, Christian Kastner, and Laurie Williams. S3C2 Summit 2023-06: Government Secure Supply Chain Summit. *arXiv preprint arXiv:2308.06850*, 2023. URL <https://arxiv.org/abs/2308.06850>.
- [50] Abdullah Y. Etcibasi, Zachary Dobos, and C. Emre Koksak. Organizational Security Resource Estimation via Vulnerability Queueing. *arXiv preprint arXiv:2604.10250*, 2026. URL <https://arxiv.org/abs/2604.10250>.
- [51] Talaya Farasat and Joachim Posegga. Machine Learning Techniques for Python Source Code Vulnerability Detection. *arXiv preprint arXiv:2404.09537*, 2024. URL <https://arxiv.org/abs/2404.09537>.
- [52] Talaya Farasat and Joachim Posegga. Optimizing Code Embeddings and ML Classifiers for Python Source Code Vulnerability Detection. *arXiv preprint arXiv:2509.13134*, 2025. URL <https://arxiv.org/abs/2509.13134>.
- [53] Miles Farmer, Ekinan Ufuktepe, Anne Watson, Hialo Muniz Carvalho, Vadim Okun, Zineb Maasaoui, and Kannappan Palaniappan. Software Vulnerability Detection Using a Lightweight Graph Neural Network. *arXiv preprint arXiv:2603.29216*, 2026. URL <https://arxiv.org/abs/2603.29216>.
- [54] Jugal Gajjar, Kamalasankari Subramaniakuppusamy, Relsy Puthal, and Kaustik Ranaware. SecureFixAgent: A Hybrid LLM Agent for Automated Python Static Vulnerability Repair. *arXiv preprint arXiv:2509.16275*, 2025. URL <https://arxiv.org/abs/2509.16275>.
- [55] Yogya Gamage, Nadia Gonzalez Fernandez, Martin Monperrus, and Benoit Baudry. Software Bills of Materials in Maven Central. *arXiv preprint arXiv:2501.13832*, 2025. URL <https://arxiv.org/abs/2501.13832>.
- [56] Hang Gao, Xiaoyu Chen, Baoquan Cui, Zhen Tang, Peng Qiao, Fengge Wu, and Jian Zhang. LLM-Enhanced Hierarchical Heterogeneous Graph Representation Learning for Malicious Python Package Detection. *arXiv preprint arXiv:2607.03350*, 2026. URL <https://arxiv.org/abs/2607.03350>.
- [57] Xingan Gao, Xiaobing Sun, Sicong Cao, Kaifeng Huang, Di Wu, Xiaolei Liu, Xingwei Lin, and Yang Xiang. MalGuard: Towards Real-Time, Accurate, and Actionable Detection of Malicious Packages in PyPI Ecosystem. *arXiv preprint arXiv:2506.14466*, 2025. URL <https://arxiv.org/abs/2506.14466>.
- [58] Zeyu Gao, Hao Wang, Yuchen Zhou, Wenyu Zhu, and Chao Zhang. How Far Have We Gone in Vulnerability Detection Using Large Language Models. *arXiv preprint arXiv:2311.12420*, 2023. URL <https://arxiv.org/abs/2311.12420>.
- [59] Jonah Ghebremichael, Saastha Vasan, Saad Ullah, Greg Tystahl, David Adei, Christopher Kruegel, Giovanni Vigna, William Enck, and Alexandros Kapravelos. Multi-Agent Taint Specification Extraction for Vulnerability Detection. *arXiv preprint arXiv:2601.10865*, 2026. URL <https://arxiv.org/abs/2601.10865>.
- [60] Rajdeep Ghosh, Shiladitya De, and Mainack Mondal. "I wasn't sure if this is indeed a security risk": Data-driven Understanding of Security Issue Reporting in GitHub Repositories of Open Source npm Packages. *arXiv preprint arXiv:2506.07728*, 2025. URL <https://arxiv.org/abs/2506.07728>.
- [61] Jose Goncalves, Tiago Dias, Eva Maia, and Isabel Praca. SCoPE: Evaluating LLMs for Software Vulnerability Detection. *arXiv preprint arXiv:2407.14372*, 2024. URL <https://arxiv.org/abs/2407.14372>.
- [62] Jose Goncalves, Miguel Silva, Eva Maia, and Isabel Praca. Enhancing Large Language Models with Faster Code Preprocessing for Vulnerability Detection. *arXiv preprint arXiv:2505.05600*, 2025. URL <https://arxiv.org/abs/2505.05600>.
- [63] Wenbo Guo, Zhengzi Xu, Chengwei Liu, Cheng Huang, Yong Fang, and Yang Liu. An Empirical Study of Malicious Code In PyPI Ecosystem. *arXiv preprint arXiv:2309.11021*, 2023. URL <https://arxiv.org/abs/2309.11021>.
- [64] Wenbo Guo, Chengwei Liu, Limin Wang, Yiran Zhang, Jiahui Wu, Zhengzi Xu, and Yang Liu. IntelliRadar: A Comprehensive Platform to Pinpoint Malicious Package Information from Cyber Intel-

- ligence. *arXiv preprint arXiv:2409.15049*, 2024. URL <https://arxiv.org/abs/2409.15049>.
- [65] Wenbo Guo, Zhongwen Chen, Zhengzi Xu, Chengwei Liu, Ming Kang, Shiwen Song, Chengyue Liu, Yijia Xu, Weisong Sun, and Yang Liu. Understanding NPM Malicious Package Detection: A Benchmark-Driven Empirical Analysis. *arXiv preprint arXiv:2603.27549*, 2026. URL <https://arxiv.org/abs/2603.27549>.
- [66] Wenbo Guo, Chengwei Liu, Ming Kang, Yiran Zhang, Jiahui Wu, Zhengzi Xu, Vinay Sachidananda, and Yang Liu. Cutting the Gordian Knot: Detecting Malicious PyPI Packages via a Knowledge-Mining Framework. *arXiv preprint arXiv:2601.16463*, 2026. URL <https://arxiv.org/abs/2601.16463>.
- [67] Wenbo Guo, Shiwen Song, Jiaxun Guo, Zhengzi Xu, Chengwei Liu, Haoran Ou, Mengmeng Ge, and Yang Liu. Bridging Expert Reasoning and LLM Detection: A Knowledge-Driven Framework for Malicious Packages. *arXiv preprint arXiv:2601.16458*, 2026. URL <https://arxiv.org/abs/2601.16458>.
- [68] S. Halder, M. Bewong, A. Mahboubi, Y. Jiang, R. Islam, Z. Islam, R. Ip, E. Ahmed, G. Ramachandran, and A. Babar. Malicious Package Detection using Metadata Information. *arXiv preprint arXiv:2402.07444*, 2024. URL <https://arxiv.org/abs/2402.07444>.
- [69] Sajal Halder, Muhammad Ejaz Ahmed, and Seyit Camtepe. FuncVul: An Effective Function Level Vulnerability Detection Model using LLM and Code Chunk. *arXiv preprint arXiv:2506.19453*, 2025. URL <https://arxiv.org/abs/2506.19453>.
- [70] Sivana Hamer, Pat Morrison, William Enck, Yasemin Acar, Michel Cukier, Alexandros Kapravelos, Christian Kastner, Dominik Wermke, and Laurie Williams. S3C2 Summit 2025-07: Government Secure Supply Chain Summit. *arXiv preprint arXiv:2605.29140*, 2026. URL <https://arxiv.org/abs/2605.29140>.
- [71] Hazim Hanif and Sergio Maffei. VulBERTa: Simplified Source Code Pre-Training for Vulnerability Detection. *arXiv preprint arXiv:2205.12424*, 2022. URL <https://arxiv.org/abs/2205.12424>.
- [72] Md Nazmul Haque, Elizabeth Lin, Lawrence Arkoh, Biruk Tadesse, and Bowen Xu. Secure or Suspect? Investigating Package Hallucinations of Shell Command in Original and Quantized LLMs. *arXiv preprint arXiv:2512.08213*, 2025. URL <https://arxiv.org/abs/2512.08213>.
- [73] Md Wasiul Haque, Md Erfan, Sagar Dasgupta, Md Rayhanur Rahman, and Mizanur Rahman. Security Vulnerabilities in Software Supply Chain for Autonomous Vehicles. *arXiv preprint arXiv:2509.16899*, 2025. URL <https://arxiv.org/abs/2509.16899>.
- [74] Behnaz Hassanshahi, Trong Nhan Mai, Benjamin Selwyn Smith, and Nicholas Allen. Unlocking Reproducibility: Automating re-Build Process for Open-Source Software. *arXiv preprint arXiv:2509.08204*, 2025. URL <https://arxiv.org/abs/2509.08204>.
- [75] Hao He, Bogdan Vasilescu, and Christian Kastner. Pinning Is Futile: You Need More Than Local Dependency Versioning to Defend against Supply Chain Attacks. *arXiv preprint arXiv:2502.06662*, 2025. URL <https://arxiv.org/abs/2502.06662>.
- [76] Joseph Hejderup, Moritz Beller, Konstantinos Triantafyllou, and Georgios Gousios. Prazi: From Package-based to Call-based Dependency Networks. *arXiv preprint arXiv:2101.09563*, 2021. URL <https://arxiv.org/abs/2101.09563>.
- [77] David Hin, Andrey Kan, Huaming Chen, and M. Ali Babar. LineVD: Statement-level Vulnerability Detection using Graph Neural Networks. *arXiv preprint arXiv:2203.05181*, 2022. URL <https://arxiv.org/abs/2203.05181>.
- [78] S M Mostaq Hossain, Amani Altarawneh, and Jesse Roberts. Leveraging Large Language Models and Machine Learning for Smart Contract Vulnerability Detection. *arXiv preprint arXiv:2501.02229*, 2025. URL <https://arxiv.org/abs/2501.02229>.
- [79] Yinghan Hou, Zongyou Yang, Zaihu Pang, and Xiujuan Ma. SkillSieve: A Hierarchical Triage Framework for Detecting Malicious AI Agent Skills. *arXiv preprint arXiv:2604.06550*, 2026. URL <https://arxiv.org/abs/2604.06550>.
- [80] Chia-Yi Hsu, Chia-Mu Yu, Chun-Ying Huang, and Jun Sakuma. Harmless Yet Harmful: Neutral Prompting Attacks for Stealthy Hallucination Steering in Agent Skills. *arXiv preprint arXiv:2605.29354*, 2026. URL <https://arxiv.org/abs/2605.29354>.
- [81] Yanzhe Hu, Shenao Wang, Tianyuan Nie, Yanjie Zhao, and Haoyu Wang. Understanding Large Language Model Supply Chain: Structure, Domain, and Vulnerabilities. *arXiv preprint arXiv:2504.20763*, 2025. URL <https://arxiv.org/abs/2504.20763>.
- [82] Cheng Huang, Nannan Wang, Ziyang Wang, Siqi Sun, Lingzi Li, Junren Chen, Qianchong Zhao, Jiaxuan Han, Zhen Yang, and Lei Shi. DONAPI: Malicious NPM Packages Detector using Behavior Sequence Knowledge Mapping. *arXiv preprint arXiv:2403.08334*, 2024. URL <https://arxiv.org/abs/2403.08334>.
- [83] Tenghui Huang, Jinbo Wen, Jiawen Kang, Siyong Chen, Zhengtao Li, Tao Zhang, Dongning

- Liu, Jiacheng Wang, Chengjun Cai, Yinqiu Liu, and Dusit Niyato. ParaVul: A Parallel Large Language Model and Retrieval-Augmented Framework for Smart Contract Vulnerability Detection. *arXiv preprint arXiv:2510.17919*, 2025. URL <https://arxiv.org/abs/2510.17919>.
- [84] Nasir Hussain, Haohan Chen, Chanh Tran, Philip Huang, Zhuohao Li, Pravir Chugh, William Chen, Ashish Kundu, and Yuan Tian. VulBinLLM: LLM-powered Vulnerability Detection for Stripped Binaries. *arXiv preprint arXiv:2505.22010*, 2025. URL <https://arxiv.org/abs/2505.22010>.
- [85] Motunrayo Ibiyo, Thinakone Louangdy, Phuong T. Nguyen, Claudio Di Sipio, and Davide Di Ruscio. Detecting Malicious Source Code in PyPI Packages with LLMs: Does RAG Come in Handy? *arXiv preprint arXiv:2504.13769*, 2025. URL <https://arxiv.org/abs/2504.13769>.
- [86] Nasif Imtiaz and Laurie Williams. Are your dependencies code reviewed?: Measuring code review coverage in dependency updates. *arXiv preprint arXiv:2206.09422*, 2022. URL <https://arxiv.org/abs/2206.09422>.
- [87] Nasif Imtiaz, Anika Khanom, and Laurie Williams. Open or Sneaky? Fast or Slow? Light or Heavy?: Investigating Security Releases of Open Source Packages. *arXiv preprint arXiv:2112.06804*, 2021. URL <https://arxiv.org/abs/2112.06804>.
- [88] Nasif Imtiaz, Seaver Thorne, and Laurie Williams. A Comparative Study of Vulnerability Reporting by Software Composition Analysis Tools. *arXiv preprint arXiv:2108.12078*, 2021. URL <https://arxiv.org/abs/2108.12078>.
- [89] Eman Abu Ishgair, Marcela S. Melara, and Santiago Torres-Arias. SoK: A Defense-Oriented Evaluation of Software Supply Chain Security. *arXiv preprint arXiv:2405.14993*, 2024. URL <https://arxiv.org/abs/2405.14993>.
- [90] Ala Jararweh, Michael Adams, Avinash Sahu, Abdullah Mueen, and Afsah Anwar. LLaVul: A Multimodal LLM for Interpretable Vulnerability Reasoning about Source Code. *arXiv preprint arXiv:2509.17337*, 2025. URL <https://arxiv.org/abs/2509.17337>.
- [91] Omar Javed and Salman Toor. Understanding the Quality of Container Security Vulnerability Detection Tools. *arXiv preprint arXiv:2101.03844*, 2021. URL <https://arxiv.org/abs/2101.03844>.
- [92] Changguo Jia, Tianqi Zhao, Runzhi He, and Minghui Zhou. Skills Are Not Islands: Measuring Dependency and Risk in Agent Skill Supply Chains. *arXiv preprint arXiv:2607.01136*, 2026. URL <https://arxiv.org/abs/2607.01136>.
- [93] Wenxin Jiang, Berk Cakar, Mikola Lysenko, and James C. Davis. ConfuGuard: Using Metadata to Detect Active and Stealthy Package Confusion Attacks Accurately and at Scale. *arXiv preprint arXiv:2502.20528*, 2025. URL <https://arxiv.org/abs/2502.20528>.
- [94] Shravya Kanchi, Xiaoyan Zang, Ying Zhang, Danfeng Yao, and Na Meng. Generating Proof-of-Vulnerability Tests to Help Enhance the Security of Complex Software. *arXiv preprint arXiv:2605.03956*, 2026. URL <https://arxiv.org/abs/2605.03956>.
- [95] Haney Kang, Eduard Marin, Myoungsung You, Diego Perino, Seungwon Shin, and Jinwoo Kim. BEACON: Automatic Container Policy Generation using Environment-aware Dynamic Analysis. *arXiv preprint arXiv:2512.00414*, 2025. URL <https://arxiv.org/abs/2512.00414>.
- [96] Berkay Kaplan and Jingyu Qian. A Survey on Common Threats in npm and PyPi Registries. *arXiv preprint arXiv:2108.09576*, 2021. URL <https://arxiv.org/abs/2108.09576>.
- [97] Caelin Kaplan, Alexander Warnecke, and Neil Archibald. BlackIce: A Containerized Red Teaming Toolkit for AI Security Testing. *arXiv preprint arXiv:2510.11823*, 2025. URL <https://arxiv.org/abs/2510.11823>.
- [98] Noor Khalal, Chakib Fettal, Lazhar Labiod, and Mohamed Nadif. When Labels Are Scarce: A Systematic Mapping of Label-Efficient Code Vulnerability Detection. *arXiv preprint arXiv:2604.00079*, 2026. URL <https://arxiv.org/abs/2604.00079>.
- [99] Rio Kishimoto, Tetsuya Kanda, Yuki Manabe, Katsuro Inoue, Shi Qiu, and Yoshiki Higo. A Dataset of Software Bill of Materials for Evaluating SBOM Consumption Tools. *arXiv preprint arXiv:2504.06880*, 2025. URL <https://arxiv.org/abs/2504.06880>.
- [100] Jan H. Klemmer, Stefan Albert Horstmann, Nikhil Patnaik, Cordelia Ludden, Cordell Burton, Carson Powers, Fabio Massacci, Akond Rahman, Daniel Votipka, Heather Richter Lipford, Awais Rashid, Alena Naiakshina, and Sascha Fahl. Using AI Assistants in Software Development: A Qualitative Study on Security Practices and Concerns. *arXiv preprint arXiv:2405.06371*, 2024. URL <https://arxiv.org/abs/2405.06371>.
- [101] Arjun Krishna, Erick Galinkin, Leon Derczynski, and Jeffrey Martin. Importing Phantoms: Measuring LLM Package Hallucination Vulnerabilities. *arXiv preprint arXiv:2501.19012*, 2025. URL <https://arxiv.org/abs/2501.19012>.
- [102] Shree Hari Bittugondanahalli Indra Kumar, Lilia Rodrigues Sampaio, Andre Martin, Andrey Brito, and Christof Fetzer. A Comprehensive

- Study on the Impact of Vulnerable Dependencies on Open-Source Software. *arXiv preprint arXiv:2512.03868*, 2025. URL <https://arxiv.org/abs/2512.03868>.
- [103] Piergiorgio Ladisa, Serena Elisa Ponta, Nicola Ronzoni, Matias Martinez, and Olivier Barais. On the Feasibility of Cross-Language Detection of Malicious Packages in npm and PyPI. *arXiv preprint arXiv:2310.09571*, 2023. URL <https://arxiv.org/abs/2310.09571>.
- [104] Piergiorgio Ladisa, Merve Sahin, Serena Elisa Ponta, Marco Rosa, Matias Martinez, and Olivier Barais. The Hitchhiker’s Guide to Malicious Third-Party Dependencies. *arXiv preprint arXiv:2307.09087*, 2023. URL <https://arxiv.org/abs/2307.09087>.
- [105] Evangelos Lamprou, Julian Dai, Grigoris Ntousakis, Martin C. Rinard, and Nikos Vasilakis. Lexo: Eliminating Stealthy Supply-Chain Attacks via LLM-Assisted Program Regeneration. *arXiv preprint arXiv:2510.14522*, 2025. URL <https://arxiv.org/abs/2510.14522>.
- [106] Ioannis Lamprou, Alexander Shevtsov, Ioannis Arapakis, and Sotiris Ioannidis. White-Basilisk: A Hybrid Model for Code Vulnerability Detection. *arXiv preprint arXiv:2507.08540*, 2025. URL <https://arxiv.org/abs/2507.08540>.
- [107] Aymen Lassoued, Nacef Mbarek, Bechir Dardouri, Bassem Ouni, Qing Li, and Fakhri Karay. VulnScout-C: A Lightweight Transformer for C Code Vulnerability Detection. *arXiv preprint arXiv:2603.28309*, 2026. URL <https://arxiv.org/abs/2603.28309>.
- [108] Amine Lbath. Toward Scalable Automated Repository-Level Datasets for Software Vulnerability Detection. *arXiv preprint arXiv:2603.17974*, 2026. URL <https://arxiv.org/abs/2603.17974>.
- [109] Sung Une Lee, Liming Dong, Zhenchang Xing, Muhammad Ejaz Ahmed, and Stefan Avgoustakis. Software Security Mapping Framework: Operationalization of Security Requirements. *arXiv preprint arXiv:2506.11051*, 2025. URL <https://arxiv.org/abs/2506.11051>.
- [110] Chaofan Li, Lyuye Zhang, Jintao Zhai, Siyue Feng, Xichun Yang, Huahao Wang, Shihan Dou, Yu Ji, Yutao Hu, Yueming Wu, Yang Liu, and Deqing Zou. Towards Security-Auditable LLM Agents: A Unified Graph Representation. *arXiv preprint arXiv:2605.06812*, 2026. URL <https://arxiv.org/abs/2605.06812>.
- [111] Haoyang Li, Mingjin Li, Jinxin Zuo, Siqi Li, Xiao Li, Hao Wu, Yueming Lu, and Xiaochuan He. CoT-Deceptor: Adversarial Code Obfuscation Against CoT-Enhanced LLM Code Agents. *arXiv preprint arXiv:2512.21250*, 2025. URL <https://arxiv.org/abs/2512.21250>.
- [112] Xiang Li, Yueci Su, Jiahao Liu, Zhiwei Lin, Yuebing Hou, Peiming Gao, and Yuanchao Zhang. VULSOLVER: Vulnerability Detection via LLM-Driven Constraint Solving. *arXiv preprint arXiv:2509.00882*, 2025. URL <https://arxiv.org/abs/2509.00882>.
- [113] Xiao Li, Yue Li, Hao Wu, Yue Zhang, Yechao Zhang, Fengyuan Xu, and Sheng Zhong. A Systematic Study of Code Obfuscation Against LLM-based Vulnerability Detection. *arXiv preprint arXiv:2512.16538*, 2025. URL <https://arxiv.org/abs/2512.16538>.
- [114] Xiaofan Li and Xing Gao. Investigating Security Implications of Automatically Generated Code on the Software Supply Chain. *arXiv preprint arXiv:2509.20277*, 2025. URL <https://arxiv.org/abs/2509.20277>.
- [115] Yu Li, Wei Ma, Zhi Chen, Ye Liu, Lingxiao Jiang, Junyi Tao, Hao Liu, Yongqiang Lyu, and Qiang Hu. AgentGuard: A Multi-Agent Framework for Robust Package Confusion Detection via Hybrid Search and Metadata-Content Fusion. *arXiv preprint arXiv:2604.16309*, 2026. URL <https://arxiv.org/abs/2604.16309>.
- [116] Elizabeth Lin, Jonah Ghebremichael, William Enck, Yasemin Acar, Michel Cukier, Alexandros Kapravelos, Christian Kastner, and Laurie Williams. S3C2 Summit 2025-03: Industry Secure Supply Chain Summit. *arXiv preprint arXiv:2510.24920*, 2025. URL <https://arxiv.org/abs/2510.24920>.
- [117] Wang Lingxiang, Quanzhi Fu, Wenjia Song, Gelei Deng, Yi Liu, Dan Williams, and Ying Zhang. SAVANT: Vulnerability Detection in Application Dependencies through Semantic-Guided Reachability Analysis. *arXiv preprint arXiv:2506.17798*, 2025. URL <https://arxiv.org/abs/2506.17798>.
- [118] Shaolun Liu, Sina Marefat, Omar Tsai, Yu Chen, Zecheng Deng, Jia Wang, and Mohammad A. Tayebi. PrediQL: Automated Testing of GraphQL APIs with LLMs. *arXiv preprint arXiv:2510.10407*, 2025. URL <https://arxiv.org/abs/2510.10407>.
- [119] Shigang Liu, Di Cao, Junae Kim, Tamas Abraham, Paul Montague, Seyit Camtepe, Jun Zhang, and Yang Xiang. EaTVul: ChatGPT-based Evasion Attack Against Software Vulnerability Detection. *arXiv preprint arXiv:2407.19216*, 2024. URL <https://arxiv.org/abs/2407.19216>.
- [120] Shuhan Liu, Xing Hu, Xin Xia, David Lo, and Xiaohu Yang. An Empirical Study of Vulnerable Package Dependencies in LLM Repositories. *arXiv preprint arXiv:2508.21417*, 2025. URL <https://arxiv.org/abs/2508.21417>.

- [121] Shuhan Liu, Yukai Zhao, Xing Hu, Kui Liu, Xiaohu Yang, and Xin Xia. Mitigating Package Hallucinations in Large Language Models via Model Editing. *arXiv preprint arXiv:2607.02052*, 2026. URL <https://arxiv.org/abs/2607.02052>.
- [122] Xueqing Liu, Jiangrui Zheng, Guanqun Yang, Siyan Wen, Qiushi Liu, and Xiaoyin Wang. Fast and Accurate Silent Vulnerability Fix Retrieval. *arXiv preprint arXiv:2503.22935*, 2025. URL <https://arxiv.org/abs/2503.22935>.
- [123] Yiyong Liu, Chia-Yi Hsu, Chun-Ying Huang, Michael Backes, Rui Wen, and Chia-Mu Yu. Trust Me, Import This: Dependency Steering Attacks via Malicious Agent Skills. *arXiv preprint arXiv:2605.09594*, 2026. URL <https://arxiv.org/abs/2605.09594>.
- [124] Zhongxin Liu, Zhijie Tang, Junwei Zhang, Xin Xia, and Xiaohu Yang. Pre-training by Predicting Program Dependencies for Vulnerability Analysis Tasks. *arXiv preprint arXiv:2402.00657*, 2024. URL <https://arxiv.org/abs/2402.00657>.
- [125] Ziheng Liu, Runzhi He, and Minghui Zhou. Package Dashboard: A Cross-Ecosystem Framework for Dual-Perspective Analysis of Software Packages. *arXiv preprint arXiv:2512.01630*, 2025. URL <https://arxiv.org/abs/2512.01630>.
- [126] Xiang Long, Yingjie Xia, Xiyuan Chen, and Li Kuang. VerilogLAVD: LLM-Aided Rule Generation for Vulnerability Detection in Verilog. *arXiv preprint arXiv:2508.13092*, 2025. URL <https://arxiv.org/abs/2508.13092>.
- [127] Nils Loose, Nico Winkel, Kristoffer Hempel, Felix Machtler, Julian Hans, and Thomas Eisenbarth. Coverage-Guided Multi-Agent Harness Generation for Java Library Fuzzing. *arXiv preprint arXiv:2603.08616*, 2026. URL <https://arxiv.org/abs/2603.08616>.
- [128] Daniil Lopatkin, Maksim Mitrofanov, Stanislav Rakovsky, and Aleksandr Khalikov. MOLOT System Card: Malicious Operational Logic Observation Transformer. *arXiv preprint arXiv:2606.07792*, 2026. URL <https://arxiv.org/abs/2606.07792>.
- [129] Zhengxiong Luo, Mehtab Zafar, Dylan Wolff, and Abhik Roychoudhury. Code-Augur: Agentic Vulnerability Detection via Specification Inference. *arXiv preprint arXiv:2606.18619*, 2026. URL <https://arxiv.org/abs/2606.18619>.
- [130] Jacob Mahon, Chenxi Hou, and Zhihao Yao. PyPitfall: Dependency Chaos and Software Supply Chain Vulnerabilities in Python. *arXiv preprint arXiv:2507.18075*, 2025. URL <https://arxiv.org/abs/2507.18075>.
- [131] Peter Mandl, Paul Mandl, Martin Hausl, and Maximilian Auch. A Ground-Truth-Based Evaluation of Vulnerability Detection Across Multiple Ecosystems. *arXiv preprint arXiv:2604.21111*, 2026. URL <https://arxiv.org/abs/2604.21111>.
- [132] Qiheng Mao, Zhenhao Li, Xing Hu, Kui Liu, Xin Xia, and Jianling Sun. Towards Explainable Vulnerability Detection with Large Language Models. *arXiv preprint arXiv:2406.09701*, 2024. URL <https://arxiv.org/abs/2406.09701>.
- [133] Alan L. McCann. Cryptographic Registry Provenance: Structural Defense Against Dependency Confusion in AI Package Ecosystems. *arXiv preprint arXiv:2605.03309*, 2026. URL <https://arxiv.org/abs/2605.03309>.
- [134] Sk Tanzir Mehedi, Chadni Islam, Gowri Ramachandran, and Raja Jurdak. DySec: A Machine Learning-based Dynamic Analysis for Detecting Malicious Packages in PyPI Ecosystem. *arXiv preprint arXiv:2503.00324*, 2025. URL <https://arxiv.org/abs/2503.00324>.
- [135] Sk Tanzir Mehedi, Raja Jurdak, Chadni Islam, and Gowri Ramachandran. QUT-DV25: A Dataset for Dynamic Analysis of Next-Gen Software Supply Chain Attacks. *arXiv preprint arXiv:2505.13804*, 2025. URL <https://arxiv.org/abs/2505.13804>.
- [136] Sk Tanzir Mehedi, Raja Jurdak, Chadni Islam, Abu Bakar Siddique Mahi, and Gowri Ramachandran. eDySec: A Deep Learning-based Explainable Dynamic Analysis Framework for Detecting Malicious Packages in PyPI Ecosystem. *arXiv preprint arXiv:2604.26219*, 2026. URL <https://arxiv.org/abs/2604.26219>.
- [137] Qiyue Mei and Michael Fu. IntelliSA: An Intelligent Static Analyzer for IaC Security Smell Detection Using Symbolic Rules and Neural Inference. *arXiv preprint arXiv:2601.14595*, 2026. URL <https://arxiv.org/abs/2601.14595>.
- [138] Amir M. Mir, Mehdi Keshani, and Sebastian Proksch. On the Effect of Transitivity and Granularity on Vulnerability Propagation in the Maven Ecosystem. *arXiv preprint arXiv:2301.07972*, 2023. URL <https://arxiv.org/abs/2301.07972>.
- [139] Mehdi Mirakhorli, Derek Garcia, Schuyler Dillon, Kevin Laporte, Matthew Morrison, Henry Lu, Viktoria Koscinski, and Christopher Enoch. A Landscape Study of Open Source and Proprietary Tools for Software Bill of Materials (SBOM). *arXiv preprint arXiv:2402.11151*, 2024. URL <https://arxiv.org/abs/2402.11151>.
- [140] Audris Mockus. The Reciprocal Impact of Science and Software: A Cross-Corpus Analysis of How Research Shapes Software and Software Enables Research. *arXiv preprint arXiv:2606.28120*, 2026. URL <https://arxiv.org/abs/2606.28120>.

- [141] Ahmad Mohsin, Helge Janicke, Adrian Wood, Iqbal H. Sarker, Leandros Maglaras, and Naeem Janjua. Can We Trust Large Language Models Generated Code? A Framework for In-Context Learning, Security Patterns, and Code Evaluations Across Diverse LLMs. *arXiv preprint arXiv:2406.12513*, 2024. URL <https://arxiv.org/abs/2406.12513>.
- [142] Biagio Montaruli, Luca Compagna, Serena Elisa Ponta, and Davide Balzarotti. One Detector Fits All: Robust and Adaptive Detection of Malicious Packages from PyPI to Enterprises. *arXiv preprint arXiv:2512.04338*, 2025. URL <https://arxiv.org/abs/2512.04338>.
- [143] Jose Miguel Moreno, Narseo Vallina-Rodriguez, and Juan Tapiador. Fakeium: A Dynamic Execution Environment for JavaScript Program Analysis. *arXiv preprint arXiv:2410.20862*, 2024. URL <https://arxiv.org/abs/2410.20862>.
- [144] Samuel Nathanson, Alexander Lee, Catherine Chen Kieffer, Jared Junkin, Jessica Ye, Amir Saeed, Melanie Lockhart, Russ Fink, Elisha Peterson, and Lanier Watkins. AI Bill of Materials and Beyond: Systematizing Security Assurance through the AI Risk Scanning (AIRS) Framework. *arXiv preprint arXiv:2511.12668*, 2025. URL <https://arxiv.org/abs/2511.12668>.
- [145] Sebastian Neef, Luca Jungnickel, Antonio Benjamin Buchholz, Valene Spence, and Vicente Birke Gonzalez. Evaluating LLMs for Real-World Web Vulnerability Detection. *arXiv preprint arXiv:2606.21397*, 2026. URL <https://arxiv.org/abs/2606.21397>.
- [146] Dang-Khoa Nguyen, Gia-Thang Ho, Quang-Minh Pham, Tuyet A. Dang-Thi, Minh-Khanh Vu, Thanh-Cong Nguyen, Phat T. Tran-Truong, and Duc-Ly Vu. Taint-Based Code Slicing for LLMs-based Malicious NPM Package Detection. *arXiv preprint arXiv:2512.12313*, 2025. URL <https://arxiv.org/abs/2512.12313>.
- [147] Thanh-Cong Nguyen, Ngoc-Thanh Nguyen, Van-Giau Ung, and Duc-Ly Vu. Towards Classifying Benign And Malicious Packages Using Machine Learning. *arXiv preprint arXiv:2511.15033*, 2025. URL <https://arxiv.org/abs/2511.15033>.
- [148] The Anh Nguyen, Triet Huynh Minh Le, and M. Ali Babar. Securing the AI Supply Chain: What Can We Learn From Developer-Reported Security Issues and Solutions of AI Projects? *arXiv preprint arXiv:2512.23385*, 2025. URL <https://arxiv.org/abs/2512.23385>.
- [149] Van-Anh Nguyen, Dai Quoc Nguyen, Van Nguyen, Trung Le, Quan Hung Tran, and Dinh Phung. ReGVD: Revisiting Graph Neural Networks for Vulnerability Detection. *arXiv preprint arXiv:2110.07317*, 2021. URL <https://arxiv.org/abs/2110.07317>.
- [150] Ronghao Ni, Mihai Christodorescu, and Limin Jia. Taint-Style Vulnerability Detection and Confirmation for Node.js Packages Using LLM Agent Reasoning. *arXiv preprint arXiv:2604.20179*, 2026. URL <https://arxiv.org/abs/2604.20179>.
- [151] Yuzhou Nie, Hongwei Li, Chengquan Guo, Ruizhe Jiang, Zhun Wang, Bo Li, Dawn Song, and Wenbo Guo. VulnLLM-R: Specialized Reasoning LLM with Agent Scaffold for Vulnerability Detection. *arXiv preprint arXiv:2512.07533*, 2025. URL <https://arxiv.org/abs/2512.07533>.
- [152] Bowei Ning, Xuejun Zong, Lian Lian, Kan He, Yifei Sun, Yuxiang Lei, and Plamen Vasilev. Securing the Dark Matter: A Semantic-Enhanced Neuro-Symbolic Framework for Supply Chain Analysis of Opaque Industrial Software. *arXiv preprint arXiv:2605.07737*, 2026. URL <https://arxiv.org/abs/2605.07737>.
- [153] Oleksii Novikov, Davide Fucci, Oleksandr Adamov, and Daniel Mendez. Policy-driven Software Bill of Materials on GitHub: An Empirical Study. *arXiv preprint arXiv:2509.01255*, 2025. URL <https://arxiv.org/abs/2509.01255>.
- [154] Lina Ochoa, Thomas Degueule, Jean-Remy Falleri, and Jurgen Vinju. Breaking Bad? Semantic Versioning and Impact of Breaking Changes in Maven Central. *arXiv preprint arXiv:2110.07889*, 2021. URL <https://arxiv.org/abs/2110.07889>.
- [155] Eric O'Donoghue, Yvette Hastings, Ernesto Ortiz, and A. Redempta Manzi Muneza. Software Bill of Materials in Software Supply Chain Security A Systematic Literature Review. *arXiv preprint arXiv:2506.03507*, 2025. URL <https://arxiv.org/abs/2506.03507>.
- [156] Marc Ohm, Henrik Plate, Arnold Sykosch, and Michael Meier. Backstabber's Knife Collection: A Review of Open Source Software Supply Chain Attacks. *arXiv preprint arXiv:2005.09535*, 2020. URL <https://arxiv.org/abs/2005.09535>.
- [157] Can Ozkan, Xinhai Zou, and Dave Singelee. Supply Chain Insecurity: The Lack of Integrity Protection in SBOM Solutions. *arXiv preprint arXiv:2412.05138*, 2024. URL <https://arxiv.org/abs/2412.05138>.
- [158] Francesco Pagano, Lorenzo Pisu, Leonardo Regano, Davide Maiorca, Alessio Merlo, and Giorgio Giacinto. Obfuscating Code Vulnerabilities against Static Analysis in JavaScript Code. *arXiv preprint arXiv:2604.01131*, 2026. URL <https://arxiv.org/abs/2604.01131>.
- [159] Siyuan Pang, Yepeng Yao, Zhengwei Jiang, Zijing Fan, Haozhe Li, and Baoxu Liu. PYPILINE: Mal-

- cious PyPI Package Detection via Suspicious API Knowledge and Agent Workflow. *arXiv preprint arXiv:2606.19063*, 2026. URL <https://arxiv.org/abs/2606.19063>.
- [160] Nikolaos Pantelaos and Alexandros Kapravelos. FV8: A Forced Execution JavaScript Engine for Detecting Evasive Techniques. *arXiv preprint arXiv:2405.13175*, 2024. URL <https://arxiv.org/abs/2405.13175>.
- [161] Brent Pappas and Paul Gazzillo. Build Code is Still Code: Finding the Antidote for Pipeline Poisoning. *arXiv preprint arXiv:2601.08995*, 2026. URL <https://arxiv.org/abs/2601.08995>.
- [162] Sunha Park, Soojin Han, and Seunghoon Woo. Uncovering Similar but Different Packages in PyPI and Potential Security Threats. *arXiv preprint arXiv:2606.29785*, 2026. URL <https://arxiv.org/abs/2606.29785>.
- [163] Chetan Pathade, Vinod Dhiman, Sheheryar Ahmad, and Ilsa Lareb. Serverless AI Security: Attack Surface Analysis and Runtime Protection Mechanisms for FaaS-Based Machine Learning. *arXiv preprint arXiv:2601.11664*, 2026. URL <https://arxiv.org/abs/2601.11664>.
- [164] Chenyang Peng, Haijun Wang, Yin Wu, Hao Wu, Ming Fan, Yitao Zhao, and Ting Liu. ETrace: Event-Driven Vulnerability Detection in Smart Contracts via LLM-Based Trace Analysis. *arXiv preprint arXiv:2506.15790*, 2025. URL <https://arxiv.org/abs/2506.15790>.
- [165] Xin Peng, Shangwen Wang, Yihao Qin, Bo Lin, Liqian Chen, and Xiaoguang Mao. Keep It Simple: Towards Accurate Vulnerability Detection for Large Code Graphs. *arXiv preprint arXiv:2412.10164*, 2024. URL <https://arxiv.org/abs/2412.10164>.
- [166] Anthony Peruma, Truman Choy, Gerald Lee, and Italo De Oliveira Santos. Understanding npm Developers' Practices, Challenges, and Recommendations for Secure Package Development. *arXiv preprint arXiv:2601.20240*, 2026. URL <https://arxiv.org/abs/2601.20240>.
- [167] Donald Pinckney, Federico Cassano, Arjun Guha, and Jonathan Bell. npm-follower: A Complete Dataset Tracking the NPM Ecosystem. *arXiv preprint arXiv:2308.12545*, 2023. URL <https://arxiv.org/abs/2308.12545>.
- [168] Donald Pinckney, Federico Cassano, Arjun Guha, and Jonathan Bell. A Large Scale Analysis of Semantic Versioning in NPM. *arXiv preprint arXiv:2304.00394*, 2023. URL <https://arxiv.org/abs/2304.00394>.
- [169] Rakesh Podder, Rafael Fabian Gonzalez Arellano, and Indrajit Ray. Hidden Amplifiers: Cross-Level Risk in Software Supply Chains. *arXiv preprint arXiv:2607.05894*, 2026. URL <https://arxiv.org/abs/2607.05894>.
- [170] Piotr Przymus and Thomas Durieux. Wolves in the Repository: A Software Engineering Analysis of the XZ Utils Supply Chain Attack. *arXiv preprint arXiv:2504.17473*, 2025. URL <https://arxiv.org/abs/2504.17473>.
- [171] Weiliang Qi, Jiahao Cao, Darsh Poddar, Sophia Li, and Xinda Wang. Enhancing Pre-Trained Language Models for Vulnerability Detection via Semantic-Preserving Data Augmentation. *arXiv preprint arXiv:2410.00249*, 2024. URL <https://arxiv.org/abs/2410.00249>.
- [172] Petar Radanliev, Carsten Maple, Omar Santos, and Kayvan Atefi. SBOMs into Agentic AIBOMs: Schema Extensions, Agentic Orchestration, and Reproducibility Evaluation. *arXiv preprint arXiv:2603.10057*, 2026. URL <https://arxiv.org/abs/2603.10057>.
- [173] Petar Radanliev, Omar Santos, Carsten Maple, and Kay Atefi. Operationalising Artificial Intelligence Bills of Materials (AIBOMs) for Verifiable AI Provenance and Lifecycle Assurance. *arXiv preprint arXiv:2605.19755*, 2026. URL <https://arxiv.org/abs/2605.19755>.
- [174] Imranur Rahman, Yasemin Acar, Michel Cukier, William Enck, Christian Kastner, Alexandros Kapravelos, Dominik Wermke, and Laurie Williams. S3C2 Summit 2024-09: Industry Secure Software Supply Chain Summit. *arXiv preprint arXiv:2505.10538*, 2025. URL <https://arxiv.org/abs/2505.10538>.
- [175] Imranur Rahman, Jill Marley, William Enck, and Laurie Williams. Which Is Better For Reducing Outdated and Vulnerable Dependencies: Pinning or Floating? *arXiv preprint arXiv:2510.08609*, 2025. URL <https://arxiv.org/abs/2510.08609>.
- [176] Md Atiqur Rahman, Yasemin Acar, Michel Cucker, William Enck, Alexandros Kapravelos, Christian Kastner, Dominik Wermke, and Laurie Williams. S3C2 Summit 2025-09: Industry Secure Supply Chain Summit. *arXiv preprint arXiv:2605.29226*, 2026. URL <https://arxiv.org/abs/2605.29226>.
- [177] Solal Rapaport, Laurent Pautet, Samuel Tardieu, Stefano Zacchiroli, and Theo Zimmermann. Mutating the "Immutable": A Large-Scale Study of Git Tag Alterations. *arXiv preprint arXiv:2606.31354*, 2026. URL <https://arxiv.org/abs/2606.31354>.
- [178] Avilash Rath, Weiliang Qi, Youpeng Li, and Xinda Wang. NatGVD: Natural Adversarial Example Attack towards Graph-based Vulnerability Detection. *arXiv preprint arXiv:2510.04987*, 2025. URL <https://arxiv.org/abs/2510.04987>.

- [179] Abhishek Reddypalle, Dennis Roellke, and Santiago Torres-Arias. Software Dark Matter: Gazing at Uncharted Files to Navigate SBOM Integrations. *arXiv preprint arXiv:2606.13966*, 2026. URL <https://arxiv.org/abs/2606.13966>.
- [180] Dalila Ressi, Alvis Spano, Lorenzo Benetollo, Carla Piazza, Michele Bugliesi, and Sabina Rossi. Vulnerability Detection in Ethereum Smart Contracts via Machine Learning: A Qualitative Analysis. *arXiv preprint arXiv:2407.18639*, 2024. URL <https://arxiv.org/abs/2407.18639>.
- [181] Frank Reyes, Federico Bono, Aman Sharma, Benoit Baudry, and Martin Monperrus. Maven-Hijack: Software Supply Chain Attack Exploiting Packaging Order. *arXiv preprint arXiv:2407.18760*, 2024. URL <https://arxiv.org/abs/2407.18760>.
- [182] Henry Ruckman-Utting, Vrushal Nedungadi, Taiga Okuma, LeTian Wang, Stephen Ehebald, and Mohammad A. Tayebi. DEPTEx: Organization-First, Open Source Dependency Risk Monitoring. *arXiv preprint arXiv:2605.00179*, 2026. URL <https://arxiv.org/abs/2605.00179>.
- [183] Jukka Ruohonen, Kalle Hjerpe, and Kalle Rindell. A Large-Scale Security-Oriented Static Analysis of Python Packages in PyPI. *arXiv preprint arXiv:2107.12699*, 2021. URL <https://arxiv.org/abs/2107.12699>.
- [184] Jukka Ruohonen, Kalle Hjerpe, and Eun-Young Kang. A Mapping Analysis of Requirements Between the CRA and the GDPR. *arXiv preprint arXiv:2503.01816*, 2025. URL <https://arxiv.org/abs/2503.01816>.
- [185] Ahmed Ryan, Ibrahim Khalil, Abdullah Al Jahid, Md Erfan, Sungbin Park, Akond Ashfaqur Rahman, and Md Rayhanur Rahman. Mind the Gap: Evaluating LLMs for High-Level Malicious Package Detection vs. Fine-Grained Indicator Identification. *arXiv preprint arXiv:2602.16304*, 2026. URL <https://arxiv.org/abs/2602.16304>.
- [186] Vadim Safronov, Ionut Bostan, Nicholas Allott, and Andrew Martin. UniBOM – A Unified SBOM Analysis and Visualisation Tool for IoT Systems and Beyond. *arXiv preprint arXiv:2511.22359*, 2025. URL <https://arxiv.org/abs/2511.22359>.
- [187] Vadim Safronov, Anthony McCaigue, Nicholas Allott, and Andrew Martin. TAIBOM: Bringing Trustworthiness to AI-Enabled Systems. *arXiv preprint arXiv:2510.02169*, 2025. URL <https://arxiv.org/abs/2510.02169>.
- [188] Amanpreet Singh Saimbhi. Enhancing Software Vulnerability Detection Using Code Property Graphs and Convolutional Neural Networks. *arXiv preprint arXiv:2503.18175*, 2025. URL <https://arxiv.org/abs/2503.18175>.
- [189] Haya Samaana, Diego Elias Costa, Emad Shihab, and Ahmad Abdellatif. A Machine Learning-Based Approach For Detecting Malicious PyPI Packages. *arXiv preprint arXiv:2412.05259*, 2024. URL <https://arxiv.org/abs/2412.05259>.
- [190] Igor Santos-Grueiro. On Good Authority: Release-Authority Measurement for Registry-Mediated Package Ecosystems. *arXiv preprint arXiv:2606.22593*, 2026. URL <https://arxiv.org/abs/2606.22593>.
- [191] Larissa Schmid, Elias Lundell, Yogya Gamage, Benoit Baudry, and Martin Monperrus. Maven-Lockfile: High Integrity Rebuild of Past Java Releases. *arXiv preprint arXiv:2510.00730*, 2025. URL <https://arxiv.org/abs/2510.00730>.
- [192] Larissa Schmid, Diogo Gaspar, Raphina Liu, Sofia Bobadilla, Benoit Baudry, and Martin Monperrus. Software Supply Chain Smells: Lightweight Analysis for Secure Dependency Management. *arXiv preprint arXiv:2603.24282*, 2026. URL <https://arxiv.org/abs/2603.24282>.
- [193] David Schmidt, Sebastian Schrittwieser, and Edgar Weippl. Supply Chain Insecurity: Exposing Vulnerabilities in iOS Dependency Management Systems. *arXiv preprint arXiv:2601.20638*, 2026. URL <https://arxiv.org/abs/2601.20638>.
- [194] Stefan Schott, Serena Elisa Ponta, Wolfram Fischer, Jonas Klauke, and Eric Bodden. Bytecode-centric Detection of Known-to-be-vulnerable Dependencies in Java Projects. *arXiv preprint arXiv:2510.19393*, 2025. URL <https://arxiv.org/abs/2510.19393>.
- [195] Stefan Schott, Serena Elisa Ponta, Wolfram Fischer, Jonas Klauke, and Eric Bodden. Uncovering Hidden Inclusions of Vulnerable Dependencies in Real-World Java Projects. *arXiv preprint arXiv:2601.23020*, 2026. URL <https://arxiv.org/abs/2601.23020>.
- [196] Adriana Sejfia and Max Schafer. Practical Automated Detection of Malicious npm Packages. *arXiv preprint arXiv:2202.13953*, 2022. URL <https://arxiv.org/abs/2202.13953>.
- [197] Christoph Sendner, Ruizi Zhang, Alexander Heftner, Alexandra Dmitrienko, and Farinaz Koushanfar. G-Scan: Graph Neural Networks for Line-Level Vulnerability Identification in Smart Contracts. *arXiv preprint arXiv:2307.08549*, 2023. URL <https://arxiv.org/abs/2307.08549>.
- [198] Daniele Serafini and Stefano Zacchiroli. Efficient Prior Publication Identification for Open Source Code. *arXiv preprint arXiv:2207.11057*, 2022. URL <https://arxiv.org/abs/2207.11057>.
- [199] Bharathi Seshadri, Yongkui Han, Chris Olson, David Pollak, and Vojislav Tomasevic. Omni-

- BOR: A System for Automatic, Verifiable Artifact Resolution across Software Supply Chains. *arXiv preprint arXiv:2402.08980*, 2024. URL <https://arxiv.org/abs/2402.08980>.
- [200] Aman Sharma, Martin Wittlinger, Benoit Baudry, and Martin Monperrus. SBOM.EXE: Countering Dynamic Code Injection based on Software Bill of Materials in Java. *arXiv preprint arXiv:2407.00246*, 2024. URL <https://arxiv.org/abs/2407.00246>.
- [201] Mikhail Shcherbakov, Paul Moosbrugger, and Musard Balliu. Unveiling the Invisible: Detection and Evaluation of Prototype Pollution Gadgets with Dynamic Taint Analysis. *arXiv preprint arXiv:2311.03919*, 2023. URL <https://arxiv.org/abs/2311.03919>.
- [202] Ze Sheng, Fenghua Wu, Xiangwu Zuo, Chao Li, Yuxin Qiao, and Lei Hang. LProtector: An LLM-driven Vulnerability Detection System. *arXiv preprint arXiv:2411.06493*, 2024. URL <https://arxiv.org/abs/2411.06493>.
- [203] Ze Sheng, Zhicheng Chen, Shuning Gu, Heqing Huang, Guofei Gu, and Jeff Huang. LLMs in Software Security: A Survey of Vulnerability Detection Techniques and Insights. *arXiv preprint arXiv:2502.07049*, 2025. URL <https://arxiv.org/abs/2502.07049>.
- [204] Alexey Shestov, Rodion Levichev, Ravil Mussabayev, Evgeny Maslov, Anton Cheshkov, and Pavel Zadorozhny. Finetuning Large Language Models for Vulnerability Detection. *arXiv preprint arXiv:2401.17010*, 2024. URL <https://arxiv.org/abs/2401.17010>.
- [205] Honglin Shu, Michael Fu, Junji Yu, Dong Wang, Chakkrit Tantithamthavorn, Junjie Chen, and Yasutaka Kamei. Evaluating Large Language Models for Multilingual Vulnerability Detection at Dual Granularities. *arXiv preprint arXiv:2506.07503*, 2025. URL <https://arxiv.org/abs/2506.07503>.
- [206] Marco Simoni, Aleksandar Fontana, Giulio Rossolini, and Andrea Saracino. Improving LLM Reasoning for Vulnerability Detection via Group Relative Policy Optimization. *arXiv preprint arXiv:2507.03051*, 2025. URL <https://arxiv.org/abs/2507.03051>.
- [207] Deniz Simsek, Aryaz Eghbali, and Michael Pradel. PoCGen: Generating Proof-of-Concept Exploits for Vulnerabilities in Npm Packages. *arXiv preprint arXiv:2506.04962*, 2025. URL <https://arxiv.org/abs/2506.04962>.
- [208] Tanmay Singla, Dharun Anandayavaraj, Kelechi G. Kalu, Taylor R. Schorlemmer, and James C. Davis. An Empirical Study on Using Large Language Models to Analyze Software Supply Chain Security Failures. *arXiv preprint arXiv:2308.04898*, 2023. URL <https://arxiv.org/abs/2308.04898>.
- [209] Pavel Snopov and Andrey Nikolaevich Golubinskiy. Vulnerability Detection via Topological Analysis of Attention Maps. *arXiv preprint arXiv:2410.03470*, 2024. URL <https://arxiv.org/abs/2410.03470>.
- [210] Lus Soeiro, Thomas Robert, and Stefano Zacchiroli. Wild SBOMs: a Large-scale Dataset of Software Bills of Materials from Public Code. *arXiv preprint arXiv:2503.15021*, 2025. URL <https://arxiv.org/abs/2503.15021>.
- [211] Leo Song, Steven H. H. Ding, Yuan Tian, Li Tao Li, Philippe Charland, and Andrew Walenstein. Chain-of-Experts (CoE): Reverse Engineering Software Bills of Materials for JavaScript Application Bundles through Code Clone Search. *arXiv preprint arXiv:2408.16198*, 2024. URL <https://arxiv.org/abs/2408.16198>.
- [212] Tom Sorger, Eric Cornelissen, Aman Sharma, Javier Ron, Musard Balliu, and Martin Monperrus. zkSBOM: Privacy-Preserving SBOM Sharing with Zero-Knowledge Sets. *arXiv preprint arXiv:2605.00076*, 2026. URL <https://arxiv.org/abs/2605.00076>.
- [213] Marcin Spoczynski, Marcela S. Melara, and Sebastian Szyller. Atlas: A Framework for ML Lifecycle Provenance & Transparency. *arXiv preprint arXiv:2502.19567*, 2025. URL <https://arxiv.org/abs/2502.19567>.
- [214] Joseph Spracklen, Raveen Wijewickrama, A H M Nazmus Sakib, Anindya Maiti, Bimal Viswanath, and Murtuza Jadliwala. We Have a Package for You! A Comprehensive Analysis of Package Hallucinations by Code Generating LLMs. *arXiv preprint arXiv:2406.10279*, 2024. URL <https://arxiv.org/abs/2406.10279>.
- [215] Naveen Srinivasan, Nathan Naveen, and Neil Naveen. Bomfather: An eBPF-based Kernel-level Monitoring Framework for Accurate Identification of Unknown, Unused, and Dynamically Loaded Dependencies in Modern Software Supply Chains. *arXiv preprint arXiv:2503.02097*, 2025. URL <https://arxiv.org/abs/2503.02097>.
- [216] Benjamin Steenhoek, Hongyang Gao, and Wei Le. Dataflow Analysis-Inspired Deep Learning for Efficient Vulnerability Detection. *arXiv preprint arXiv:2212.08108*, 2022. URL <https://arxiv.org/abs/2212.08108>.
- [217] Benjamin Steenhoek, Md Mahbubur Rahman, Richard Jiles, and Wei Le. An Empirical Study of Deep Learning Models for Vulnerability Detection. *arXiv preprint arXiv:2212.08109*, 2022. URL <https://arxiv.org/abs/2212.08109>.
- [218] Benjamin Steenhoek, Md Mahbubur Rahman,

- Monoshi Kumar Roy, Mirza Sanjida Alam, Hengbo Tong, Swarna Das, Earl T. Barr, and Wei Le. To Err is Machine: Vulnerability Detection Challenges LLM Reasoning. *arXiv preprint arXiv:2403.17218*, 2024. URL <https://arxiv.org/abs/2403.17218>.
- [219] Zhihong Sun, Jia Li, Yao Wan, Chuanyi Li, Hongyu Zhang, Zhi jin, Ge Li, Hong Liu, Chen Lyu, and Songlin Hu. Ensembling Large Language Models for Code Vulnerability Detection: An Empirical Evaluation. *arXiv preprint arXiv:2509.12629*, 2025. URL <https://arxiv.org/abs/2509.12629>.
- [220] Surada Suwansathit, Yuxuan Zhang, and Guofei Gu. A Security Analysis of the OpenClaw AI Agent Framework. *arXiv preprint arXiv:2603.27517*, 2026. URL <https://arxiv.org/abs/2603.27517>.
- [221] Ben Swierzy, Timo Pohl, Marc Ohm, and Michael Meier. How Reliable Are FOSS Popularity Metrics? Analyzing the Effort Required for Spoofing Common Software Popularity Metrics. *arXiv preprint arXiv:2505.05897*, 2025. URL <https://arxiv.org/abs/2505.05897>.
- [222] Toqeer Ali Syed, Mohammad Riyaz Belgaum, Salman Jan, Asadullah Abdullah Khan, and Saad Said Alqahtani. Agentic AI for Autonomous Defense in Software Supply Chain Security: Beyond Provenance to Vulnerability Mitigation. *arXiv preprint arXiv:2512.23480*, 2025. URL <https://arxiv.org/abs/2512.23480>.
- [223] Mahzabin Tamanna, Sivana Hamer, Mindy Tran, Sascha Fahl, Yasemin Acar, and Laurie Williams. Analyzing Challenges in Deployment of the SLSA Framework for Software Supply Chain Security. *arXiv preprint arXiv:2409.05014*, 2024. URL <https://arxiv.org/abs/2409.05014>.
- [224] Zhuoran Tan, Christos Anagnostopoulos, and Jeremy Singer. OSPtrack: A Labeled Dataset Targeting Simulated Execution of Open-Source Software. *arXiv preprint arXiv:2411.14829*, 2024. URL <https://arxiv.org/abs/2411.14829>.
- [225] Zhuoran Tan, Wenbo Guo, Taylor Brierley, Jiewen Luo, Jeremy Singer, and Christos Anagnostopoulos. SynthChain: A Synthetic Benchmark and Forensic Analysis of Advanced and Stealthy Software Supply Chain Attacks. *arXiv preprint arXiv:2603.16694*, 2026. URL <https://arxiv.org/abs/2603.16694>.
- [226] Zhuoran Tan, Yutian Tang, Jeremy Singer, Christos Anagnostopoulos, and Ke Xiao. FuseChain: Runtime Evidence Reconstruction for Software Supply-Chain Attacks. *arXiv preprint arXiv:2606.15811*, 2026. URL <https://arxiv.org/abs/2606.15811>.
- [227] Zhuoran Tan, Ke Xiao, Jeremy Singer, and Christos Anagnostopoulos. Operational Runtime Behavior Mining for Open-Source Supply Chain Security. *arXiv preprint arXiv:2601.06948*, 2026. URL <https://arxiv.org/abs/2601.06948>.
- [228] Zixuan Tan, Jiayuan Zhou, Xing Hu, Shengyi Pan, Kui Liu, and Xin Xia. Similar but Patched Code Considered Harmful – The Impact of Similar but Patched Code on Recurring Vulnerability Detection and How to Remove Them. *arXiv preprint arXiv:2412.20740*, 2024. URL <https://arxiv.org/abs/2412.20740>.
- [229] Takeru Tanaka, Hideaki Hata, Bodin Chinthanet, Raula Gaikovina Kula, and Kenichi Matsumoto. Meta-Maintanance for Dockerfiles: Are We There Yet? *arXiv preprint arXiv:2305.03251*, 2023. URL <https://arxiv.org/abs/2305.03251>.
- [230] Stefan Tatschner, Michael P. Heintz, Nicole Pappler, Tobias Specht, Sven Plaga, and Thomas Newe. Tracking Down Software Cluster Bombs: A Current State Analysis of the Free/Libre and Open Source Software (FLOSS) Ecosystem. *arXiv preprint arXiv:2502.08219*, 2025. URL <https://arxiv.org/abs/2502.08219>.
- [231] Matthew Taylor, Ruturaj K. Vaidya, Drew Davidson, Lorenzo De Carli, and Vaibhav Rastogi. Spell-Bound: Defending Against Package Typosquatting. *arXiv preprint arXiv:2003.03471*, 2020. URL <https://arxiv.org/abs/2003.03471>.
- [232] Chayanid Termphaiboon, Raula Gaikovina Kula, Youmei Fan, Morakot Choetkiertikul, Chaoyong Ragkhitwetsagul, Thanwadee Sunetnanta, and Kenichi Matsumoto. Exploring the SECURITY.md in the Dependency Chain: Preliminary Analysis of the PyPI Ecosystem. *arXiv preprint arXiv:2511.22186*, 2025. URL <https://arxiv.org/abs/2511.22186>.
- [233] Mohamed Thariq and Indrajith Ekanayake. ARGO-SLSA: Software Supply Chain Security in Argo Workflows. *arXiv preprint arXiv:2503.20079*, 2025. URL <https://arxiv.org/abs/2503.20079>.
- [234] Takaaki Toda and Tatsuya Mori. CHASE: LLM Agents for Dissecting Malicious PyPI Packages. *arXiv preprint arXiv:2601.06838*, 2026. URL <https://arxiv.org/abs/2601.06838>.
- [235] Abdurrahman Tolay. Automated SBOM-Driven Vulnerability Triage for IoT Firmware: A Lightweight Pipeline for Risk Prioritization. *arXiv preprint arXiv:2601.01308*, 2026. URL <https://arxiv.org/abs/2601.01308>.
- [236] Omar Tsai, Jianing Li, Tsz Tung Cheung, Lejing Huang, Hao Zhu, Jianrui Xiao, Iman Sharafaldin, and Mohammad A. Tayebi. GraphQLer: Enhancing GraphQL Security with Context-Aware API Testing. *arXiv preprint arXiv:2504.13358*, 2025. URL <https://arxiv.org/abs/2504.13358>.
- [237] Chen Tsfaty and Michael Fire. Malicious Source

- Code Detection Using Transformer. *arXiv preprint arXiv:2209.07957*, 2022. URL <https://arxiv.org/abs/2209.07957>.
- [238] George Tsigkourakos and Constantinos Patsakis. QRS: A Rule-Synthesizing Neuro-Symbolic Triad for Autonomous Vulnerability Discovery. *arXiv preprint arXiv:2602.09774*, 2026. URL <https://arxiv.org/abs/2602.09774>.
- [239] Md Nizam Uddin, Yihe Zhang, and Xiali Hei. Deep Learning Aided Software Vulnerability Detection: A Survey. *arXiv preprint arXiv:2503.04002*, 2025. URL <https://arxiv.org/abs/2503.04002>.
- [240] Meet Udeshi, Venkata Sai Charan Putrevu, Prashanth Krishnamurthy, Prashant Anantharaman, Sean Carrick, Ramesh Karri, and Farshad Khorrami. Binary Diff Summarization using Large Language Models. *arXiv preprint arXiv:2509.23970*, 2025. URL <https://arxiv.org/abs/2509.23970>.
- [241] Ruturaj K. Vaidya, Lorenzo De Carli, Drew Davidson, and Vaibhav Rastogi. Security Issues in Language-based Software Ecosystems. *arXiv preprint arXiv:1903.02613*, 2019. URL <https://arxiv.org/abs/1903.02613>.
- [242] Vasudev Vikram, Yuvraj Agarwal, and Rohan Padhye. On the Freshness of Pinned Dependencies in Maven. *arXiv preprint arXiv:2510.22815*, 2025. URL <https://arxiv.org/abs/2510.22815>.
- [243] Duc-Ly Vu, Thanh-Cong Nguyen, Minh-Khanh Vu, Ngoc-Thanh Nguyen, and Kim-Anh Do Thi. Pack-A-Mal: A Malware Analysis Framework for Open-Source Packages. *arXiv preprint arXiv:2511.09957*, 2025. URL <https://arxiv.org/abs/2511.09957>.
- [244] Chengjie Wang, Jingzheng Wu, Xiang Ling, Tianyue Luo, and Chen Zhao. Correct Code, Vulnerable Dependencies: A Large Scale Measurement Study of LLM-Specified Library Versions. *arXiv preprint arXiv:2605.06279*, 2026. URL <https://arxiv.org/abs/2605.06279>.
- [245] Chengjie Wang, Jingzheng Wu, Hao Lyu, Xiang Ling, Tianyue Luo, Yanjun Wu, and Chen Zhao. A Large Scale Empirical Analysis on the Adherence Gap between Standards and Tools in SBOM. *arXiv preprint arXiv:2601.05622*, 2026. URL <https://arxiv.org/abs/2601.05622>.
- [246] Fuwei Wang, Yongzhi Liu, and Zhiqiang Dong. Patch2QL: Discover Cognate Defects in Open Source Software Supply Chain With Auto-generated Static Analysis Rules. *arXiv preprint arXiv:2401.12443*, 2024. URL <https://arxiv.org/abs/2401.12443>.
- [247] Keyu Wang, Abdullah Norozi Iranzad, Scott Schaffter, Meg Risdal, Doina Precup, and Jonathan Lebensold. Mitigating Downstream Model Risks via Model Provenance. *arXiv preprint arXiv:2410.02230*, 2024. URL <https://arxiv.org/abs/2410.02230>.
- [248] Meng Wang, Yue Ma, Majid Garoosi, Wenting Fan, Liwei Guo, Jianqiang Wang, and Ali Abasi. PyFEX: Uncovering Evasive Python-based Threats via Resilient and Exhaustive Path Exploration. *arXiv preprint arXiv:2606.02196*, 2026. URL <https://arxiv.org/abs/2606.02196>.
- [249] Xincheng Wang, Ruida Hu, Cuiyun Gao, Xincheng Wen, Yujia Chen, and Qing Liao. ReposVul: A Repository-Level High-Quality Vulnerability Dataset. *arXiv preprint arXiv:2401.13169*, 2024. URL <https://arxiv.org/abs/2401.13169>.
- [250] Yongchao Wang and Zhiqiu Huang. Security Is Relative: Training-Free Vulnerability Detection via Multi-Agent Behavioral Contract Synthesis. *arXiv preprint arXiv:2604.19012*, 2026. URL <https://arxiv.org/abs/2604.19012>.
- [251] Zhifeng Wang, Wanxuan Wu, Chunyan Zeng, Jialong Yao, Yang Yang, and Hongmin Xu. Graph Neural Networks Enhanced Smart Contract Vulnerability Detection of Educational Blockchain. *arXiv preprint arXiv:2303.04477*, 2023. URL <https://arxiv.org/abs/2303.04477>.
- [252] Ziliang Wang, Ge Li, Jia Li, Yingfei Xiong, Jia Li, Meng Yan, and Zhi Jin. M2CVD: Enhancing Vulnerability Semantic through Multi-Model Collaboration for Code Vulnerability Detection. *arXiv preprint arXiv:2406.05940*, 2024. URL <https://arxiv.org/abs/2406.05940>.
- [253] Zixin Wang. Defending the Core: A Centrality-Based Protection Strategy for Supply Chain Security in npm Dependency Network. *arXiv preprint arXiv:2606.14036*, 2026. URL <https://arxiv.org/abs/2606.14036>.
- [254] Xin-Cheng Wen, Cuiyun Gao, Jiaxin Ye, Yichen Li, Zhihong Tian, Yan Jia, and Xuan Wang. Meta-Path Based Attentional Graph Learning Model for Vulnerability Detection. *arXiv preprint arXiv:2212.14274*, 2022. URL <https://arxiv.org/abs/2212.14274>.
- [255] Xin-Cheng Wen, Yupan Chen, Cuiyun Gao, Hongyu Zhang, Jie M. Zhang, and Qing Liao. Vulnerability Detection with Graph Simplification and Enhanced Graph Representation Learning. *arXiv preprint arXiv:2302.04675*, 2023. URL <https://arxiv.org/abs/2302.04675>.
- [256] Xin-Cheng Wen, Cuiyun Gao, Shuzheng Gao, Yang Xiao, and Michael R. Lyu. SCALE: Constructing Structured Natural Language Comment Trees for Software Vulnerability Detection. *arXiv preprint arXiv:2403.19096*, 2024. URL <https://arxiv.org/abs/2403.19096>.

- [257] Xin-Cheng Wen, Cuiyun Gao, Xincheng Wang, Ruiqi Wang, Tao Zhang, and Qing Liao. Game Rewards Vulnerabilities: Software Vulnerability Detection with Zero-Sum Game and Prototype Learning. *arXiv preprint arXiv:2401.08131*, 2024. URL <https://arxiv.org/abs/2401.08131>.
- [258] Xin-Cheng Wen, Xincheng Wang, Yujia Chen, Ruida Hu, David Lo, and Cuiyun Gao. VulEval: Towards Repository-Level Evaluation of Software Vulnerability Detection. *arXiv preprint arXiv:2404.15596*, 2024. URL <https://arxiv.org/abs/2404.15596>.
- [259] Ka Wai Wu. Strengthening DeFi Security: A Static Analysis Approach to Flash Loan Vulnerabilities. *arXiv preprint arXiv:2411.01230*, 2024. URL <https://arxiv.org/abs/2411.01230>.
- [260] Zekun Wu, Seonglae Cho, Umar Mohammed, Cristian Munoz, Kleyton Costa, Xin Guan, Theo King, Ze Wang, Emre Kazim, and Adriano Koshiyama. LibVulnWatch: A Deep Assessment Agent System and Leaderboard for Uncovering Hidden Vulnerabilities in Open-Source AI Libraries. *arXiv preprint arXiv:2505.08842*, 2025. URL <https://arxiv.org/abs/2505.08842>.
- [261] Boming Xia, Tingting Bi, Zhenchang Xing, Qinghua Lu, and Liming Zhu. An Empirical Study on Software Bill of Materials: Where We Stand and the Road Ahead. *arXiv preprint arXiv:2301.05362*, 2023. URL <https://arxiv.org/abs/2301.05362>.
- [262] Boming Xia, Dawen Zhang, Yue Liu, Qinghua Lu, Zhenchang Xing, and Liming Zhu. Trust in Software Supply Chains: Blockchain-Enabled SBOM and the AIBOM Future. *arXiv preprint arXiv:2307.02088*, 2023. URL <https://arxiv.org/abs/2307.02088>.
- [263] Howell Xia, Jonah Gluck, Sevval Simsek, David Sastre Medina, and David Starobinski. VDGraph: A Graph-Theoretic Approach to Unlock Insights from SBOM and SCA Data. *arXiv preprint arXiv:2507.20502*, 2025. URL <https://arxiv.org/abs/2507.20502>.
- [264] Haoran Xu, Chen Zhi, Junxiao Han, Xinkui Zhao, Jianwei Yin, and Shuiguang Deng. Revisiting Vulnerability Patch Localization: An Empirical Study and LLM-Based Solution. *arXiv preprint arXiv:2509.15777*, 2025. URL <https://arxiv.org/abs/2509.15777>.
- [265] Shangzhi Xu, Jialiang Dong, Weiting Cai, Juanru Li, Arash Shaghagh, Nan Sun, and Siqi Ma. Enhancing Security in Third-Party Library Reuse – Comprehensive Detection of 1-day Vulnerability through Code Patch Analysis. *arXiv preprint arXiv:2411.19648*, 2024. URL <https://arxiv.org/abs/2411.19648>.
- [266] Shenao Yan, Shima Ahmed, Shan Jin, Sunpreet S. Arora, Yiwei Cai, Yizhen Wang, and Yuan Hong. Detecting Data Poisoning in Code Generation LLMs via Black-Box, Vulnerability-Oriented Scanning. *arXiv preprint arXiv:2603.17174*, 2026. URL <https://arxiv.org/abs/2603.17174>.
- [267] Zihe Yan, Kai Luo, Haoyu Yang, Yang Yu, Zhuosheng Zhang, and Guancheng Li. An LLM-based Quantitative Framework for Evaluating High-Stealthy Backdoor Risks in OSS Supply Chains. *arXiv preprint arXiv:2511.13341*, 2025. URL <https://arxiv.org/abs/2511.13341>.
- [268] Aidan Z. H. Yang, Haoye Tian, He Ye, Ruben Martins, and Claire Le Goues. Security Vulnerability Detection with Multitask Self-Instructed Fine-Tuning of Large Language Models. *arXiv preprint arXiv:2406.05892*, 2024. URL <https://arxiv.org/abs/2406.05892>.
- [269] Shuo Yang, Xinran Zheng, Jinfeng Xu, Jinze Li, Danyang Song, Zheyu Chen, and Edith C. H. Ngai. Generative AI for Vulnerability Detection in 6G Wireless Networks: Advances, Case Study, and Future Directions. *arXiv preprint arXiv:2506.20488*, 2025. URL <https://arxiv.org/abs/2506.20488>.
- [270] Yanjing Yang, Xin Zhou, Runfeng Mao, Jinwei Xu, Lanxin Yang, Yu Zhang, Haifeng Shen, and He Zhang. DLAP: A Deep Learning Augmented Large Language Model Prompting Framework for Software Vulnerability Detection. *arXiv preprint arXiv:2405.01202*, 2024. URL <https://arxiv.org/abs/2405.01202>.
- [271] Yixin Yang, Bowen Xu, Xiang Gao, and Hailong Sun. Context-Enhanced Vulnerability Detection Based on Large Language Model. *arXiv preprint arXiv:2504.16877*, 2025. URL <https://arxiv.org/abs/2504.16877>.
- [272] Yong Yang, Xing Zheng, Huiyu Wu, Huangsheng Cheng, Xiaorong Shi, Jing Guo, Bo Yang, Yi Zhou, Xiangfan Wu, and Zonghao Ying. Securing the AI Agent: A Unified Framework for Multi-Layer Agent Red Teaming. *arXiv preprint arXiv:2606.31227*, 2026. URL <https://arxiv.org/abs/2606.31227>.
- [273] Corey Yang-Smith and Ahmad Abdellatif. Tracing Vulnerabilities in Maven: A Study of CVE life-cycles and Dependency Networks. *arXiv preprint arXiv:2502.04621*, 2025. URL <https://arxiv.org/abs/2502.04621>.
- [274] Yury Yanovich, Victoria Kovalevskaya, Maksim Egorov, Elizaveta Smirnova, Matvey Mishuris, Yash Madhwal, Kirill Ziborov, Vladimir Gorgadze, and Subodh Sharma. BugMagnifier: TON Transaction Simulator for Revealing Smart Contract Vulnerabilities. *arXiv preprint arXiv:2509.24444*, 2025. URL <https://arxiv.org/abs/2509.24444>.

- [275] Rajesh Yarra. LLMpatronous: Harnessing the Power of LLMs For Vulnerability Detection. *arXiv preprint arXiv:2504.18423*, 2025. URL <https://arxiv.org/abs/2504.18423>.
- [276] Kai Ye, Liangcai Su, and Chenxiong Qian. ImportSnare: Directed "Code Manual" Hijacking in Retrieval-Augmented Code Generation. *arXiv preprint arXiv:2509.07941*, 2025. URL <https://arxiv.org/abs/2509.07941>.
- [277] Ziyang Ye, Triet Huynh Minh Le, and M. Ali Babar. LLMSecConfig: An LLM-Based Approach for Fixing Software Container Misconfigurations. *arXiv preprint arXiv:2502.02009*, 2025. URL <https://arxiv.org/abs/2502.02009>.
- [278] Junji Yu, Honglin Shu, Michael Fu, Dong Wang, Chakkrit Tantithamthavorn, Yasutaka Kamei, and Junjie Chen. A Preliminary Study of Large Language Models for Multilingual Vulnerability Detection. *arXiv preprint arXiv:2505.07376*, 2025. URL <https://arxiv.org/abs/2505.07376>.
- [279] Jihyeon Yun, Abdullah Yasin Etcibasi, Ming Shi, and C. Emre Koksall. A Queueing-Theoretic Framework for Dynamic Attack Surfaces: Data-Integrated Risk Analysis and Adaptive Defense. *arXiv preprint arXiv:2604.10427*, 2026. URL <https://arxiv.org/abs/2604.10427>.
- [280] Oualid Zaazaa and Hanan El Bakkali. SmartLLM-Sentry: A Comprehensive LLM Based Smart Contract Vulnerability Detection Framework. *arXiv preprint arXiv:2411.19234*, 2024. URL <https://arxiv.org/abs/2411.19234>.
- [281] Nusrat Zahan, Thomas Zimmermann, Patrice Godefroid, Brendan Murphy, Chandra Maddila, and Laurie Williams. What are Weak Links in the npm Supply Chain? *arXiv preprint arXiv:2112.10165*, 2021. URL <https://arxiv.org/abs/2112.10165>.
- [282] Nusrat Zahan, Philipp Burckhardt, Mikola Lysenko, Feross Aboukhadijeh, and Laurie Williams. Leveraging Large Language Models to Detect npm Malicious Packages. *arXiv preprint arXiv:2403.12196*, 2024. URL <https://arxiv.org/abs/2403.12196>.
- [283] Muhammad Umar Zeshan, Motunrayo Ibiyo, Claudio Di Sipio, Phuong T. Nguyen, and Davide Di Ruscio. Many Hands Make Light Work: An LLM-based Multi-Agent System for Detecting Malicious PyPI Packages. *arXiv preprint arXiv:2601.12148*, 2026. URL <https://arxiv.org/abs/2601.12148>.
- [284] Chenyuan Zhang, Hao Liu, Jiutian Zeng, Kejing Yang, Yuhong Li, and Hui Li. Prompt-Enhanced Software Vulnerability Detection Using ChatGPT. *arXiv preprint arXiv:2308.12697*, 2023. URL <https://arxiv.org/abs/2308.12697>.
- [285] Junan Zhang, Kaifeng Huang, Yiheng Huang, Bi-huan Chen, Ruisi Wang, Chong Wang, and Xin Peng. Killing Two Birds with One Stone: Malicious Package Detection in NPM and PyPI using a Single Model of Malicious Behavior Sequence. *arXiv preprint arXiv:2309.02637*, 2023. URL <https://arxiv.org/abs/2309.02637>.
- [286] XiangRui Zhang, HaoYu Chen, Yongzhong He, Wenjia Niu, and Qiang Li. Automatically Generating Rules of Malicious Software Packages via Large Language Model. *arXiv preprint arXiv:2504.17198*, 2025. URL <https://arxiv.org/abs/2504.17198>.
- [287] Yifan Zhang, Michael Sandborn, Stefan Larson, Yu Huang, and Kevin Leach. K-ASTRO: Structure-Aware Adaptation of LLMs for Code Vulnerability Detection. *arXiv preprint arXiv:2208.08067*, 2022. URL <https://arxiv.org/abs/2208.08067>.
- [288] Ying Zhang, Mahir Kabir, Ya Xiao, Danfeng, Yao, and Na Meng. Data-Driven Vulnerability Detection and Repair in Java Code. *arXiv preprint arXiv:2102.06994*, 2021. URL <https://arxiv.org/abs/2102.06994>.
- [289] Ying Zhang, Wenjia Song, Zhengjie Ji, Danfeng, Yao, and Na Meng. How Can ChatGPT Support Human Security Testers to Help Mitigate Supply Chain Attacks? *arXiv preprint arXiv:2310.00710*, 2023. URL <https://arxiv.org/abs/2310.00710>.
- [290] Ying Zhang, Xiaoyan Zhou, Hui Wen, Wenjia Niu, Jiqiang Liu, Haining Wang, and Qiang Li. Tactics, Techniques, and Procedures (TTPs) in Interpreted Malware: A Zero-Shot Generation with Large Language Models. *arXiv preprint arXiv:2407.08532*, 2024. URL <https://arxiv.org/abs/2407.08532>.
- [291] Jieming Zheng, Hao Guan, and Yepang Liu. When LLMs Invent Rust Crates: An Empirical Study of Hallucination Patterns and Mitigation. *arXiv preprint arXiv:2606.08444*, 2026. URL <https://arxiv.org/abs/2606.08444>.
- [292] Weining Zheng, Yuan Jiang, and Xiaohong Su. VulSPG: Vulnerability detection based on slice property graph representation learning. *arXiv preprint arXiv:2109.02527*, 2021. URL <https://arxiv.org/abs/2109.02527>.
- [293] Xinran Zheng, Xingzhi Qian, Huichi Zhou, Shuo Yang, Yiling He, Suman Jana, and Lorenzo Cavallaro. Learning to Focus: Context Extraction for Efficient Code Vulnerability Detection with Language Models. *arXiv preprint arXiv:2505.17460*, 2025. URL <https://arxiv.org/abs/2505.17460>.
- [294] Xinyi Zheng, Chen Wei, Shenao Wang, Yanjie Zhao, Peiming Gao, Yuanchao Zhang, Kailong Wang, and Haoyu Wang. Towards Robust Detection of Open Source Software Supply Chain Poisoning Attacks in Industry Environments. *arXiv*

- preprint arXiv:2409.09356*, 2024. URL <https://arxiv.org/abs/2409.09356>.
- [295] Zhiqing Zhong, Jiaming Huang, and Pinjia He. BackportBench: A Multilingual Benchmark for Automated Backporting of Patches. *arXiv preprint arXiv:2512.01396*, 2025. URL <https://arxiv.org/abs/2512.01396>.
 - [296] Li Zhou, Marc Dacier, and Charalambos Konstantinou. A Reality Check on SBOM-based Vulnerability Management: An Empirical Study and A Path Forward. *arXiv preprint arXiv:2511.20313*, 2025. URL <https://arxiv.org/abs/2511.20313>.
 - [297] Xiaoyan Zhou, Feiran Liang, Zhaojie Xie, Yang Lan, Wenjia Niu, Jiqiang Liu, Haining Wang, and Qiang Li. A Large-scale Fine-grained Analysis of Packages in Open-Source Software Ecosystems. *arXiv preprint arXiv:2404.11467*, 2024. URL <https://arxiv.org/abs/2404.11467>.
 - [298] Xiaoyan Zhou, Ying Zhang, Wenjia Niu, Jiqiang Liu, Haining Wang, and Qiang Li. An Analysis of Malicious Packages in Open-Source Software in the Wild. *arXiv preprint arXiv:2404.04991*, 2024. URL <https://arxiv.org/abs/2404.04991>.
 - [299] Xin Zhou, Duc-Manh Tran, Thanh Le-Cong, Ting Zhang, Ivana Clairine Irsan, Joshua Sumarlin, Bach Le, and David Lo. Comparison of Static Application Security Testing Tools and Large Language Models for Repo-level Vulnerability Detection. *arXiv preprint arXiv:2407.16235*, 2024. URL <https://arxiv.org/abs/2407.16235>.
 - [300] Haomin Zhuang, Hanwen Xing, Yujun Zhou, Yuchen Ma, Yue Huang, Yili Shen, Yufei Han, and Xiangliang Zhang. AgentTrap: Measuring Runtime Trust Failures in Third-Party Agent Skills. *arXiv preprint arXiv:2605.13940*, 2026. URL <https://arxiv.org/abs/2605.13940>.